Universidad de la Habana

Facultad de Matemática y Computación

Instituto de Criptografía



Algoritmo para la detección de Contraseñas Gráficas con patrón de suavidad en la Técnica de Autenticación Gráfica Passpoints

Tesis presentada en opción al título de

Máster en Ciencias Matemáticas

Mención Criptografía

Autor: **Ing. Osviel Rodriguez Valdés**

Tutores: **Dr. C. Carlos Miguel Legón**

Dr. C. Raisa Socorro Llanes

La Habana, diciembre de 2019

ÍNDICE GENERAL

RESUMEN v

ABSTRACT vi

INTRODUCCIÓN 1

1. FUNDAMENTOS TEÓRICOS 5

1.1. Esquemas de Autenticación y clasificaciones 5

1.1.1. Técnicas basadas en el reconocimiento de patrones de imágenes 7

1.1.2. Técnicas basadas en la memorización de patrones en imágenes 11

1.1.3. Técnicas basadas en el recuerdo con indicación 14

1.1.4. Esquemas híbridos 17

1.2. Ataques a Técnicas de Contraseñas Gráficas 18

1.2.1. Estrategias generales de ataque 18

1.2.2. Modelos de atención 19

1.2.3. Leyes de Gestalt 20

1.2.4. Estrategias de ataques basados en Técnicas de Procesamiento de Imágenes (TPI) 21

1.2.5. Ataques basados en detección de patrones 23

1.2.6. Patrones identificados en la forma y orden en que el usuario escoge los puntos (PLC) 23

1.3. Patrón de suavidad de la selección 26

1.4. Relación entre TPI y PLC 26

1.5. Seguridad y usabilidad de las Contraseñas Gráficas 27

1.6. Proactive Password Checkers 29

1.7. Conclusiones del capítulo 30

2. DETECCIÓN DE CONTRASEÑAS CON PATRÓN DE SUAVIDAD EN PASSPOINTS 32

2.1. Métodos de detección de patrones espaciales de puntos 32

2.2. Modelando la suavidad en 5 puntos 34

2.3. Algoritmo de detección de la suavidad en n puntos 37
2.3.1. Ejemplo de implementación en Python 38
2.4. Selección del parámetro $D(\varphi^0)$ 39
2.5. Discusión de los resultados 44
2.6. Factibilidad de aplicación práctica 45
2.7. Conclusiones del capítulo 45

CONCLUSIONES **47**

RECOMENDACIONES **48**

PUBLICACIONES DERIVADAS **49**

REFERENCIAS BIBLIOGRÁFICAS **50**

ÍNDICE DE FIGURAS

1.1. Categorías de los métodos de autenticación gráfica 7

1.2. Imágenes aleatorias usadas por Dhamija y Perring 8

1.3. Técnicas basadas en la memorización de objetos. 9

1.4. Ejemplo de Passfaces 10

1.5. Evolución de las técnicas de autenticación gráficas en la categoría Teécnicas basadas en el reconocimiento de patrones de imágenes 10

1.6. Técnicas basadas en la memorización de patrones sobre imágenes (Grupo 1) . . . 12

1.7. Técnicas basadas en la memorización de patrones sobre imágenes (Grupo 2) . . . 13

1.8. Evolución de las técnicas de autenticación gráficas en la categoría Técnicas basadas en la memorización de patrones en imágenes 13

1.9. Comparación de los espacios de clave para Contraseñas Alfanuméricas y Passpoints a partir del tamaño de la imagen, el tamaño de la región de tolerancia, el tamaño del alfabeto, la cantidad de puntos y/o carateres. 15

1.10. CCP: Posibles caminos en dependencia de la selección del usuario 16

1.11. Evolución de las técnicas de autenticación gráficas en la categoría Cued-Recall Based Technique 17

1.12. Leyes de Gestalt de la percepción visual. 21

1.13. Ejemplos de PLC para cada categoría de acuerdo a la forma. 24

1.14. Porciento de las contraseñas de [14] que contienen cada uno de los cinco patrones de formas 25

1.15. Ejemplos de selecciones suaves en conjuntos de 5 puntos. 26

1.16. Mayores concentraciones de HotSpots. 27

1.17. Presencia de PLC en las mayores concentraciones de HotSpots. 27

2.1. Patrones de puntos. Izquierda a derecha: Agregado, Aleatorio y Regular. 33

2.2. Dos disposiciones de puntos distintas que darían un mismo resultado al analizarse por el método de cuadrantes. 34

2.3. Posibles situaciones para el análisis de suavidad en 3 puntos. 35

2.4. Interpretación para $k = 5$ 37

2.5. Longitudes de los ángulos entre los vectores en las 124 contraseñas clasificadas con patrón de suavidad 40

2.6. Longitudes de los vectores en las 124 contraseñas clasificadas con patrón de suavidad 41

2.7. Cantidad de contraseñas que se detectan por el algoritmo con patrón de suavidad entre las 124 contraseñas clasificadas como suaves a priori para diferentes párametros de tolerancias. Eje x: Parámetro de tolerancia, Eje y: Cantidad de contraseñas. 42

2.8. Cantidad de contraseñas que se detectan por el algoritmo con patrón de suavidad entre las 397 contraseñas con todos los tipos de patrones. Eje x: Parámetro de tolerancia, Eje y: Cantidad de contraseñas. 43

2.9. Frecuencia relativa de los errores de clasificación del algoritmo (falsos positivos y falsos negativos) para diferentes valores de $D(\varphi)$. 44

RESUMEN

En los nuevos escenarios, la autenticación posee un papel importante garantizando acceso a los sistemas digitales que gestionan la información de los usuarios y empresas. Tradicionalmente se han utilizado las contraseñas alfanuméricas. Una Contraseña Alfanumérica segura debe cumplir muchos parámetros que los usuarios casi siempre ignoran para hacerla memorable. Las contraseñas que suelen emplear son sencillas y vulnerables a ataques de diccionario. Las Contraseñas Gráficas son una alternativa eficiente y segura a las Contraseñas Alfanuméricas. Las Contraseñas Gráficas requieren que el usuario recuerde una imagen o partes de ella en vez de grupos de caracteres alfanuméricos. Estas poseen espacios de claves considerables y ayudan a que el usuario recuerde mejor su contraseña. Un grupo significativo de usuarios prefieren relacionar los puntos que conforman su contraseña entre sí siguiendo caminos existentes en las imágenes de fondo. Estas formas de selección constituyen vulnerabilidades que son aprovechadas en ataques de Diccionario que buscan Patrones Lineales de Clics. El patrón de suavidad de la selección es un tipo de Patrón Lineal e Clic en el que los usuarios tienden a asociar los puntos de la contraseña y seguir caminos en las imágenes de fondo que conduzcan a "selecciones suaves". Los métodos más usados para la detección de patrones espaciales (El análisis de cuadrantes, el criterio de vecino más cercano y la función K de Ripley) no se pueden aplicar a ese nuevo escenario. En esta investigación se propone un criterio efectivo para detectar la existencia de patrones de suavidad en las contraseñas gráficas de la Técnica de Autenticación Gráfica Passpoints para imágenes de $700x400$ pixeles. Además se obtiene un algoritmo para su implementación. Se confirmó experimentalmente el criterio propuesto destacando que su aplicación práctica contribuye a aumentar la seguridad del sistema sin afectar sustancialmente su eficiencia.

ABSTRACT

In present day virtual scenarios, the authentication has an important role giving access to the systems that manage the user's personal and corporative data. Traditionally Alphanumerical Passwords have been used. A secure Alphanumerical Password has to fill lot of parameters that users usually ignore to make it memorable. The passwords they usually use are simple and vulnerable to dictionary attacks. The Graphical Passwords are an efficient and safe alternative to the Alphanumerical Passwords. Graphical Passwords require the user to remember a picture or parts of it. These ones have considerable key space and help the user to remember their password. A group of users are motivated to make a relation between the points of their password following paths in the background images. This behavior adds vulnerabilities that an attacker can use in a Click Pattern Dictionary Attack. The smooth pattern in the selection is a type of Linear and Click Pattern in which users tend to associate the points of the password and follow paths in the background images that lead to "smooth selections". The most used methods for detecting spatial patterns (Quadrant analysis, nearest neighbor criteria and Ripley's K function) cannot be used in this new scenario. This investigation proposes an effective criterion to detect the existence of smooth pattern in the graphic passwords for the Passpoints Graphic Authentication Technique in images of $700x400$ pixels. In addition, an algorithm for the implementation is obtained. The proposed criterion was experimentally confirmed, highlighting that its practical application contributes to increasing the security of the system without substantially affecting its efficiency.

INTRODUCCIÓN

El desarrollo de las tecnologías de la informática y las comunicaciones ha propiciado nuevos entornos de desarrollo social y profesional. El volumen de información sensible que se maneja en sistemas personales y profesionales sigue siendo el objetivo de los atacantes que buscan hurtar o dañar a los usuarios y a las empresas. Los mecanismos para garantizar que los sistemas y la información que estos controlan solo sean utilizados por las personas autorizadas a hacerlo son variados y poseen características que los hacen más deseables para entornos determinados.

La autenticación es el proceso de determinar si un usuario puede tener acceso a un sistema o recurso [47]. Un usuario promedio utiliza las tecnologías para acceder a todo tipo de servicios en la vida moderna (correo, cuentas bancarias, redes sociales, dispositivos móviles, servicios de comunicaciones, etc.). Los mismos, para proveer seguridad y confiabilidad, requieren del usuario algún tipo de información que de forma única lo identifique ante el sistema. Los métodos de autenticación se clasifican en tres tipos: los basados en un *token*, los basados en información biométrica y los basados en conocimiento [48].

Tradicionalmente se utilizan las Contraseñas Alfanuméricas (CA) por ser fáciles de implementar y poco costosas computacionalmente. Las CA se encuentran dentro de Los Métodos Basados en Conocimiento, son fáciles de implementar y muy comunes en todos los tipos de sistemas. Lamentablemente estas pueden ser pronosticadas o atacadas con facilidad [17, 47, 1]. Una CA fuerte debe ser aleatoria (Alta entropía), con diversidad de caracteres y larga; como consecuencia difícil de recordar [10]. Esto se conoce en la literatura como el problema de la *password* [74, 58]. Por la naturaleza de los procesos nemotécnicos cuando los usuarios tienen que establecer o recordar muchas contraseñas usualmente utilizan en sistemas distintos contraseñas parecidas o con frases sencillas para poder recordarlas [17, 25].

Según [55] los usuarios casi siempre ignoran las recomendaciones para la confección de contraseñas seguras, estas tienden a ser cortas y poco aleatorias. En [77] se demuestra que una práctica común es la de escribir en papel todas las contraseñas para no olvidarlas o utilizar la misma para todos los sistemas. En otros casos los usuarios crean sus propios procedimientos para generar contraseñas distintas, adicionando un número o una letra al final de cada palabra o nombre; aunque muchos de los sistemas modernos exigen que los usuarios cambien sus contraseñas periódicamente. Todos estos requerimientos y conductas van en detrimento de la seguridad y la información que estos sistemas manejan. Desgraciadamente existen muchas técnicas y herramientas que aprovechan estas vulnerabilidades y de una manera relativamente fácil permiten obtener la contraseña [58]. Los esquemas de Autenticación Gráficas (AG) son alternativas a

las contraseñas basadas en caracteres alfanuméricos. Estos son usados en la autenticación de usuarios en un sistema o la generación de llaves para el uso en algoritmos criptográficos.

Las Contraseñas Gráficas (CG) pueden estar formadas por la combinación de fotos, imágenes o iconografías. Dadas las características de las imágenes, estas producen un espacio de claves [1] mucho mayor y son resistentes a los ataques clásicos a contraseñas de combinación de caracteres alfanuméricas donde los usuarios para poder recordarlas utilizan frases que son relativamente predecibles.

La eficiencia de los sistemas de AG se basa en la gran capacidad de los seres humanos de recordar patrones en imágenes en vez de memorizar conjuntos de caracteres de grandes longitudes y complejidad. Aún son muchas las investigaciones que trabajan en mejorar las deficiencias de estos sistemas gráficos, pero estos poseen probadas ventajas sobre los tradicionales de introducción de texto y conservan espacios de clave considerables. Todas estas ventajas los hacen deseables y prácticos para muchos entornos donde las contraseñas basadas en caracteres alfanuméricos se olvidan por ser demasiado complejas y largas. En el peor de los casos, por ser débiles en su composición, pueden ser atacadas por los ataques de diccionario o fuerza bruta.

Las CG abarcan, además, un grupo de técnicas. Para aclarar la diferencia entre estas, la mayoría de los autores, desde 1994 hasta 2009 muestran que pueden ser clasificadas en tres grandes grupos [68]: *Recognition based technique* (Técnicas basadas en el reconocimiento), *Recall based technique* (Técnicas basadas en el recuerdo) y *Cued-recall based technique* (Técnicas basadas en el recuerdo con indicación).

Dentro de las Técnicas basadas en el recuerdo con indicación ha recibido especial atención el Passpoints [8, 77]. El Passpoints requiere que el usuario seleccione un conjunto de puntos (cinco en total) sobre una imagen [11]. Este sistema es la base de varias implementaciones de autenticación para sistemas operativos Android y Windows. Este es simple y efectivo, además soporta modificaciones que puedan personalizar sus implementaciones para cada escenario en particular. Las desventajas principales del Passpoints radican en la calidad de las imágenes que se utilizan en el proceso de autenticación [2], la existencia de patrones por la forma en la que el usuario establece su contraseña (*Clic-order patterns*) y en el uso de mecanismos de discretización que introducen vulnerabilidades propias de su funcionamiento [80, 68].

Ataques de diccionario efectivos se han realizado contra la Técnica de AG Passpoints. Estos buscan explotar dos características en la selección de la contraseña: los puntos más probables conocidos como HotSpots y los *Clic-order patterns*, Patrones de Clics también conocidos como Patrones de Clics Lineales (PCL). Los HotSpots son los puntos de una imagen más probables

[1] El espacio teórico de claves de una contraseña es el número total de contraseñas posibles que se pueden generar en un alfabeto.

[2] Las imágenes pueden contener puntos o áreas más atractivas para que el usuario las seleccione como su contraseña (HotSpots)

a seleccionar por el usuario. Estos se pueden pronosticar utilizando Técnicas de Procesamiento de Imágenes (TPI) para detectar bordes, esquinas, centroides y cambios de intensidad. Los patrones lineales de clics (PLC) son las relaciones en cuanto al orden, el sentido, espaciado y la ubicación de los puntos en las CG [15]. Ambas características constituyen debilidades de las CG que contribuyen a aumentar su predictibilidad [80].

En la Técnica de AG Passpoints, existen comportamientos descritos en [14] que fundamentan la idea de que el usuario distribuye los puntos de su contraseña en composiciones dependientes de las imágenes de fondo. Los usuarios tienden a crear caminos donde las coordenadas de los puntos poseen relación entre sí formando curvas, arcos, lineas rectas, etc. Los ataques que se han basado en la construcción de diccionarios automáticos utilizando estas predisposiciones han sido muy efectivos. Logrando recuperar hasta el 56 % de las contraseñas en diccionarios relativamente pequeños (Ej. $2^{33,02}$).

El problema de seleccionar una contraseña fuerte (sin importar si es CG o CA) se ha convertido en algo relevante para la seguridad y va más allá de cuán bien diseñado esté el sistema. Dadas las limitaciones de la memoria humana, las personas están inclinadas a escoger contraseñas sencillas y fáciles para recordar (ej. números de teléfonos, fechas de cumpleaños, nombres de familiares o amigos, palabras en el lenguaje humano, números de identidad o combinaciones de ellos). Los *Proactive Password Checker* son sistemas que ayudan al usuario desde la fase de registro en la selección de una contraseña más segura [3, 78]. Estos son ampliamente utilizados en los sistemas que emplean CA para evaluar la complejidad de la contraseña seleccionada indicándole al usuario cuán débil o fuerte puede ser su contraseña. Estos a su vez implementan procedimientos basados en criterios básicos de aceptación que le indican al usuario los puntos en los que su contraseña no es débil. Sin embargo, en la bibliografía consultada no hay reportes de su utilización en sistemas que implementan AG.

Problema de investigación:
¿Cómo detectar la introducción de una contraseña con patrón de suavidad en la Técnica de Autenticación Gráfica Passpoints?

Objeto de estudio:
Técnicas de Autenticación Gráfica.

Objetivo general:
Desarrollar un método que permita detectar durante la fase de registro la introducción de una Contraseña Gráfica con patrón de suavidad en la Técnica de Autenticación Gráfica Passpoints.

Campo de acción:
Detección de Contraseñas Gráficas con patrón de suavidad en la Técnica de Autenticación Gráfica Passpoints.

Hipótesis:

Es posible diseñar un método basado en ángulos y distancias en el plano bidimensional que detecte la introducción de una contraseña con patrón de suavidad en la Técnica de Autenticacién Gráfica Passpoints.

Objetivos específicos:
El objetivo general se desglosa en los siguientes objetivos específicos:

- Identificar los fundamentos teóricos de las Técnicas de Autenticación Gráfica.
- Identificar los fundamentos teóricos relacionados con la detección de patrones lineales en las contraseñas de la Técnica de Autenticación Gráfica Passpoints.
- Desarrollar un algoritmo que permita detectar la introducción de una contraseña con patrón de suavidad en la Técnica de Autenticación Gráfica Passpoints.
- Validar la efectividad del algoritmo.

Esta tesis está estructurada además de la introducción por dos capítulos, conclusiones, recomendaciones, publicaciones derivadas y referencias bibliográficas. En el primer capítulo se reflejan los elementos fundamentales asociados a los métodos y técnicas de autenticación. Además se presenta el resultado de dos publicaciones derivadas de la investigacón que forman parte del marco teórico: el anális de la usabilidad y la seguridad de las técnicas de autenticación gráficas y el impacto de los patrones de clics en la debilidad de las claves en la técnica de autenticación gráfica Passpoints. En el segundo capítulo se propone y valida un algoritmo para detectar la suavidad en las contraseñas de la técnica de autenticación gráfica Passpoints a partir de ángulos y distancias. Siendo este el resultado principal de la investigación.

Capítulo 1

FUNDAMENTOS TEÓRICOS

En este capítulo se presentan los principales conceptos asociados al dominio del problema que sustentan la investigación y contribuyen a la comprensión de su contenido. En este se reflejan los elementos fundamentales asociados a los métodos y técnicas de autenticación. Además se presenta el resultado de un análisis sobre los aportes más relevantes en materia de técnicas y métodos de autenticación gráfica que constituyen un referente teórico - práctico de la investigación. También se expondrán los principales ataques a los que estas son vulnerables; así como los elementos que hacen fuerte a una técnica de este tipo.

1.1. Esquemas de Autenticación y clasificaciones

Los métodos de autenticación se clasifican en tres tipos: Los basados en un *token*, Los basados en información biométrica y Los basados en conocimiento [48]. Tradicionalmente se ha utilizado las Contraseñas Alfanuméricas (CA) que son una combinación de caracteres tomados del código ASCII para generar una contraseña secreta de dimensión variable. Las CA se encuentran dentro de los métodos basados en conocimiento, son fáciles de implementar y muy comunes en todos los tipos de sistemas.

En la era digital los usuarios necesitan establecer y recordar contraseñas para muchos sistemas: contraseñas para sitios web, aplicaciones de correo, clientes de mensajería instantánea, redes sociales, cuentas bancarias, etc. Una contraseña alfanumérica fuerte debe ser aleatoria, con diversidad de caracteres y larga; como consecuencia difícil de recordar [10].

Por la naturaleza de los procesos nemotécnicos cuando los usuarios tienen que establecer o recordar muchas contraseñas usualmente utilizan en sistemas distintas contraseñas parecidas o con frases sencillas para poder recordarlas [17]. Según Schneier [55] los usuarios casi siempre ignoran las recomendaciones para la confección de contraseñas seguras, estas tienden a ser cortas y poco aleatorias.

Evidencia sustancial demuestra [77] que una práctica común es la de escribir en papel todas las contraseñas para no olvidarlas o utilizar la misma contraseña para todos los sistemas. En otros casos los usuarios crean sus propios procedimientos para generar contraseñas distintas, adicionando un número o una letra al final de cada palabra o nombre (aunque muchos de los sistemas modernos exigen que los usuarios cambien sus contraseñas periódicamente). Todos estos requerimientos y conductas van en detrimento de la seguridad de los sistemas y la información

que estos manejan. Las contraseñas alfanuméricas débiles son susceptibles a los ataques de diccionario, fuerza bruta o los basados en conocimiento sobre los usuarios.

En los esquemas de autenticación basados en token de seguridad el usuario porta un objeto que le identifica y en el cuál reside una clave de criptografía. Se utilizan combinados con contraseñas o pines para proveer seguridad a los servicios de cobro y pago en los bancos y oficinas comerciales [61]. La forma más común en la que se presentan es como tarjetas inteligentes o magnéticas (pueden verse también en muchas otras formas como dispositivos digitales y memorias USB). En este tipo de esquema el usuario debe evitar la pérdida o robo de su *token* y este es también proclive al deterioro por tiempo de uso.

Los esquemas de autenticación basados en información biométrica han obtenido recientemente mucho interés y son en muchos casos alternativas a las CA [49]. Para su implementación es necesario en todos los casos la utilización de elementos de hardware especializado. Se pueden apreciar implementaciones para computadoras personales y celulares que requieren la huella del usuario, un patrón de voz y/o en los sistemas con hardware y prestaciones más avanzadas el reconocimiento de mapas faciales tridimensionales. Este tipo de sistemas puede ser en concepción difícil de falsificar, pero relativamente fácil de robar [54] [44]. El usuario puede dejar su huella en múltiples objetos de uso diario y el atacante puede usarlas cuando este no se encuentre presente. Existe también el caso de que se vea comprometido el archivo maestro de contraseñas biométricas donde el atacante insertaría o suplantaría alguna identidad existente otorgándole acceso al sistema. El rendimiento de estos puede verse comprometido por circunstancias como la salud del usuario, estrés y otros factores que pueden hacer el proceso de identificación extenso e incómodo.

Las Contraseñas Gráficas se clasifican dentro de los sistemas de autenticación basados en conocimiento. Fueron idea original de Blonder [11] encontrándose registrada la patente a su nombre desde 1996. La habilidad humana para reconocer patrones hace que esta técnica en particular tenga ventajas sobre las Contraseñas Alfanuméricas y a su vez sea resistente a los ataques clásicos a los que estos son vulnerables. Las Contraseñas Gráficas engloban también un grupo grande de técnicas; la mayoría de los autores desde 1994 hasta 2009 muestran que pueden ser clasificadas en tres grandes grupos [5]. Nikhi y Arati [39] hacen una gran aproximación dividiendo las técnicas en tres grupos: *Recognition Based Technique* (Técnicas basadas en el reconocimiento de patrones de imágenes), *Recall Based Technique* (Técnicas basadas en el recuerdo de patrones en imágenes) y *Cued-Recall Based Technique* (Técnicas basadas en memorización de puntos claves sobre imágenes) (Figura 1.1).

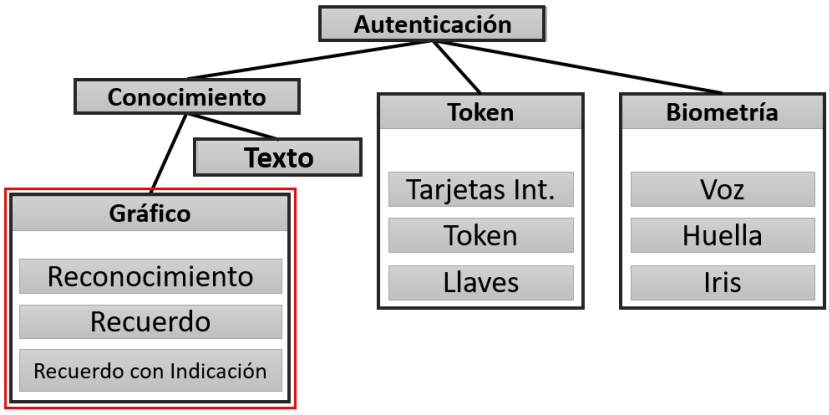


Figura 1.1: Categorías de los métodos de autenticación gráfica

1.1.1. Técnicas basadas en el reconocimiento de patrones de imágenes

Este tipo de técnica se basa en el principio del reconocimiento de patrones de imágenes siendo una de las más fáciles para la memoria humana. Muchos son los métodos dentro de esta categoría, vale hacer énfasis en los más relevantes en cuanto al aporte.

Dhamija y Perring [19] proponen un método en el que se le presenta al usuario un grupo de imágenes en orden aleatorio y de composición también aleatoria producidos por un programa (Figura 1.1.1) . Este debe en la fase de registro seleccionar las que desea para el proceso de establecer su contraseña, luego debe seleccionarlas de un grupo de imágenes mayor y también generadas de forma aleatoria para autenticarse. Dentro de las principales desventajas de este procedimiento se encuentra, la necesidad de almacenar en el servidor un portafolio para cada cliente como texto en claro. También el proceso de selección de las imágenes de la base de datos podía ser para el usuario un proceso tedioso y largo en cada ocasión que se fuera a autenticar.

Akula y Devisetty's [2] hicieron en su investigación una propuesta para optimizar el almacenamiento y la seguridad del método anterior. Plantearon que utilizando el algoritmo $SHA-1$ sobre la contraseña se puede optimizar el rendimiento y garantizar que la autenticación sea más segura y consuma menos memoria.

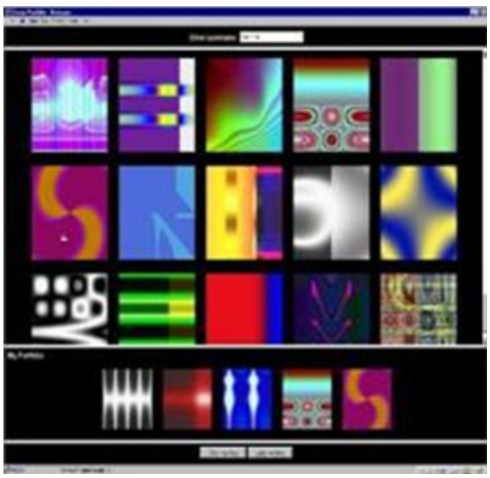


Figura 1.2: Imágenes aleatorias usadas por Dhamija y Perring

Takada y Koike [63] hacen más flexible el método anterior dándole al usuario la posibilidad de subir al servidor las imágenes que prefiera para utilizar en el proceso de autenticación.

Otras propuestas en principio similares como la de Jansen, [31] solo se diferencian en que el usuario para autenticarse debe seleccionar las imágenes en un orden correcto. Estas imágenes poseen un identificador numérico que en un orden preciso conforma la contraseña. Dado que limitan la cantidad de imágenes a 30, esto reduce el espacio de clave de forma significativa. A cada imágen se le asigna un valor numérico y la secuencia total genera una contraseña numérica. Proponen para solucionar el problema del espacio de clave utilizar combinaciones de imágenes.

En la Figura 1.3(a) se puede observar un ejemplo del método propuesto por Birget [57] resistente a los ataques de tipo *Shoulder-Surfing*. Este propone la utilización de un conjunto de objetos aleatorios en forma icónica en el que el usuario selecciona tres de ellos que corresponderían a su contraseña. Para autenticarse el usuario debe seleccionar los objetos que se encuentran dentro del triángulo que forman estos tres sobre la imágen. La correcta selección de los objetos contenidos en el interior de esta figura suponen la correcta identidad del usuario. Birget en su investigación propone la utilización de 1000 objetos distintos, esto hace que el despliegue sea muy atestado y la identificación de ellos en el marco difícil, pero usar un grupo de objetos pequeño hace que el espacio de clave sea pequeño y por lo tanto vulnerable.

Otro de los sistemas que se diseñó para que fuera resistente a los ataques tipo *Shoulder-Surfing* fué el *Movable Frame Scheme* también propuesto por Birget [57]. En el que se debían reconocer tres objetos donde uno de ellos se encontraba en un marco que se debía alinear a los demás formando una linea recta (Figura 1.3(b)) para la correcta autenticación. Para el atacante resultaría difícil saber cuáles serían los otros dos objetos que forman parte de la contraseña. Birget también proponía la utilización de 1000 objetos para que el tamaño de la contraseña fuera razonable. Teniendo en cuenta que en la Figura 1.3(b) hay alrededor de 120 objetos, en la práctica

1000 provocarían que el marco estuviera demasiado cargado y fuera difícil y largo el proceso de autenticación.

Man, et al. [**Man2003c**] crean también un algoritmo basado en la selección de un grupo de objetos representados de forma icónica, siendo este resistente a los ataques de tipo *Shoulder-Surfing*(Una descripción de este tipo de ataques puede verse en el epígrafe 4). Cada objeto posee muchas variantes y cada una de ellas posee un código único. En cada escena se ubican muchos objetos de forma aleatoria, el usuario debe introducir la secuencia de códigos correspondiente a los objetos y a sus posiciones, que conforman su contraseña (Figura 1.3(c)). Al no utilizarse el ratón para seleccionar u obtener información de los objetos, incluso si es grabado en video el procedimiento es difícil de imitar. Una de sus principales desventajas radica en que el usuario debe recordar los códigos relativos a cada objeto y sus variantes forzándolo a memorizar muchas cadenas de texto. Hong más adelante extiende el procedimiento para que los usuarios escojan las contraseñas que desean para los objetos que conforman su contraseña, aportando esto memorabilidad.



(a) Método de Birget



(b) Segunda propuesta de Birget



(c) Método de Man

Figura 1.3: Técnicas basadas en la memorización de objetos.

La *Real User Corporation* [6] propuso un método (novedoso en su momento) basado en la identificación de rostros humanos. El usuario selecciona de una base de datos cuatro imágenes que serán su contraseña. Luego para autenticarse se le muestran grupos de nueve rostros de forma

aleatoria en los que debe seleccionar por cada grupo una de las establecidas con anterioridad (Figura 1.4). En las revisiones hechas por Brostoff y Sasse [12] demostraron que el proceso es más largo que el de introducción de texto y aún la viabilidad de este sistemas es cuestionable. Otros estudios [18] demostraron que los usuarios tendían a seleccionar rostros de razas similares, esto se puede resolver haciendo recomendaciones o solo proponiendo rostros con alta aleatoriedad, pero al mismo tiempo puede atentar contra la capacidad del usuario de recordar su contraseña.



Figura 1.4: Ejemplo de Passfaces

Otros métodos conocidos como *Story* [18] y *Deja Vú* [19] tienen funcionamientos parecidos y formalizan los métodos iniciales. En el primero en la fase de registro el usuario selecciona de un portafolio un grupo de imágenes que luego debe introducir en el orden adecuado para autenticarse. En el segundo se utilizan fotos aleatorias de arte que el usuario debe recordar e identificarlas para autenticarse de un conjunto mayor.

En la figura 1.5 se puede observar un resumen de los principales métodos dentro de esta categoría y su evolución.

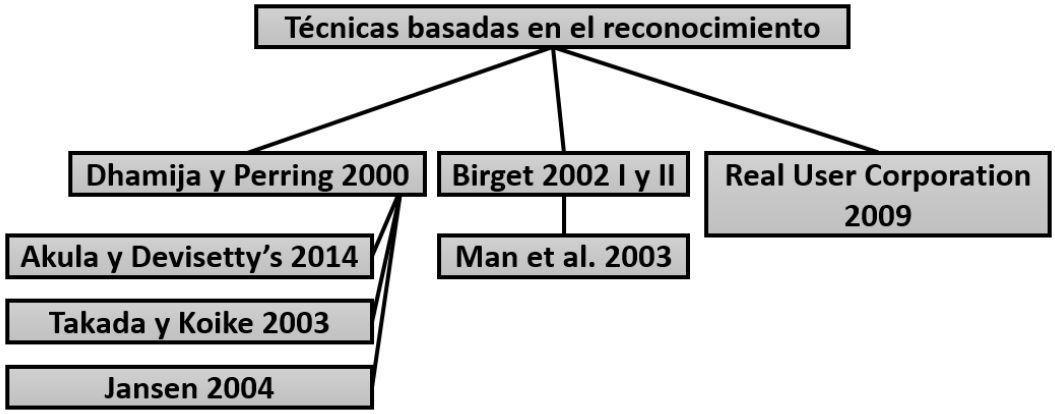


Figura 1.5: Evolución de las técnicas de autenticación gráficas en la categoría Teécnicas basadas en el reconocimiento de patrones de imágenes

1.1.2. Técnicas basadas en la memorización de patrones en imágenes

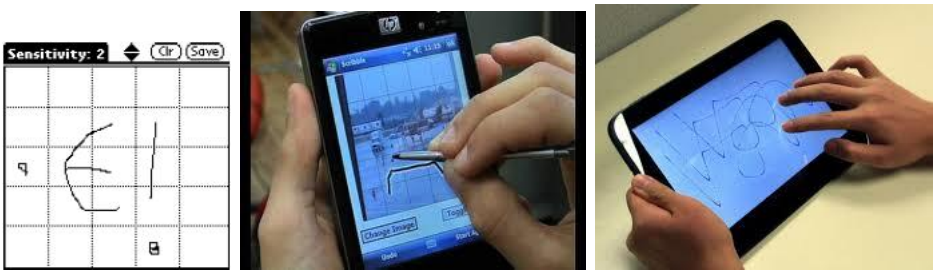
También conocidos como *Pure Recall Based Techniques*. En este tipo de sistemas los usuarios escriben su contraseña en un lienzo o sobre una imágen. El usuario reproduce en forma de dibujo lo que ha establecido en el proceso de registro.

Draw a Secret (DAS) [32] fué el primer sistema de contraseñas propuesto dentro de esta categoría. El usuario debía dibujar su contraseña en una cuadrícula $2D$ utilizando un lapicero electrónico o un mouse. El sistema interpretaba el dibujo a partir de sus coordenadas según el trazo (Figura 1.6(a)). Sorprendentemente este sistema ofrecía un espacio de clave grande comparado con el de introducción de caracteres alfanuméricos. En una cuadrícula de $5x5$ el número total de contraseñas de longitud 12 o menor era de 2,3 x 10^{17}, mayor que el de las contraseñas de caracteres alfanuméricos (ASCII) de 8 caracteres (95^8 = 6,6 x 10^{15}). Las dimensiones de la cuadrícula no debían ser ni muy grandes ni muy pequeñas, puesto que hacerlo muy pequeño atentaba contra el espacio de claves y hacerlo muy grande hacía difícil para el usuario el proceso de dibujar correctamente la contraseña de forma tal que no fuera un intento fallido. Por lo que se determina que el sistema era útil solamente en el ambiente de PDA's y dispositivos pequeños como celulares.

En 2004, Thorpe y Van Oorschot introdujeron el concepto de Diccionario Gráfico Simétrico, en su estudio basado en teorías psicológicas demuestran que las personas prefieren imágenes que exhiben modelos simétricos. Usando estos conceptos reducen el espacio de clave a 58 bits que puede ser recorrido fácilmente por los ordenadores modernos [66, 70]. Otro estudio de ese mismo año [37] señala que el 86 % de las contraseñas se crean a partir del centro de la cuadrícula y que el 45 % son totalmente simétricas, atentando esto drásticamente contra el espacio de clave.

Utilizando el mismo principio surge el BDAS (*Background Draw a Secret*) propuesto por Dunphy et al. [21] solo añadiendo una imagen de fondo para motivar al usuario a crear patrones más complejos (Figura 1.6(b)). Dunphy et al. reportaban que la imagen de fondo podía reducir las características que hacían predecible al esquema DAS, por ejemplo la simetría o el comenzar desde el centro. Este nuevo método ayudaría al usuario a crear contraseñas más seguras. En el estudio no se menciona que la imagen de fondo podía influenciar al usuario a seguir patrones o a enmarcar áreas que resultasen más probables de ser escogidas por el usuario, haciendo al método vulnerable ante ataques de diccionario.

Pass-Doodle [71] es muy parecido al DAS, pero en este los usuarios dibujan sin la existencia de una cuadrícula. Resultando más complejo el proceso de chequeo de la contraseña dado que se pueden usar varios punteros, diferentes grosores, velocidades y colores en el trazo (Figura 1.6(c)).



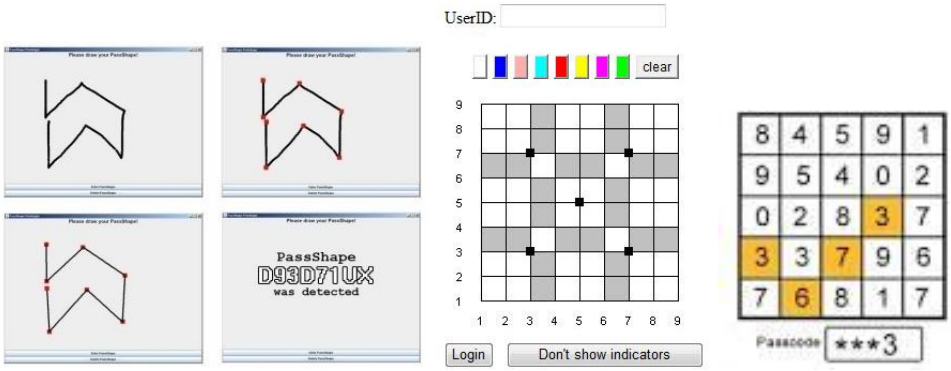
(a) DAS (b) BDAS (c) Pass-doodle

Figura 1.6: Técnicas basadas en la memorización de patrones sobre imágenes (Grupo 1)

El método *Pass-Shape* (Figura 1.7(a)) [76] es muy similar al *Pass-doodle*, las contraseñas son traducidas a caracteres alfanuméricos mediante 8 direcciones distintas del trazo a intervalos de 45°. La contraseña puede dibujarse en cualquier parte de la cuadrícula y a cualquier tamaño. Aunque es sencillo de recordar, su espacio de clave es reducido, dado que en cada cambio de ángulo solo se cuenta con 8 posibles direcciones.

Pass-Go (Figura 1.7(b)) [64] es un sistema motivado por el método DAS y la necesidad de erradicar sus deficiencias. Se basa en un antiguo juego chino llamado "Go". En este el usuario selecciona las intersecciones en una cuadrícula como su contraseña, ofreciendo un espacio de clave de 256 bits(374 bits si se tienen en cuenta la distinción por colores). El autor en su estudio plantea que sometió el método a las pruebas descritas por Thorpe y Orschot de Diccionario Gráfico y aún en el peor de los casos su resistencia a ataques se comporta igual que el esquema DAS. En su investigación Thorpe y Tao et al. [37, 42] demostraron que el 40 % de las contraseñas en el método caen en un sub-espacio definido por su simetría con respecto a los ejes central, vertical y horizontal. Demostraron además que el 72 % de las contraseñas tienen 4 o menos intersecciones. Esto reduce el espacio de clave de forma significativa y hace el sistema vulnerable a los ataques de diccionario. A pesar de estas limitaciones en la actualidad se utiliza este sistema como base para la creación de los modelos de autenticación por patrones en el sistema operativo Androide desarrollado por Google.

Surgen luego otras propuestas para solucionar las deficiencias de este sistema al crear patrones como: BPass-Go(*Background Pass-Go*) [45] muy parecidas a BDAS y MGBPG(*Multi Grid Pass-Go*) [46] también parecida a MGDAS(*Multi Grid DAS*) que buscan ampliar el espacio de clave y ayudar al usuario a recordar patrones de contraseñas más complejos.



(a) Pass Shape (b) Pass-Go (c) GrIDsure

Figura 1.7: Técnicas basadas en la memorización de patrones sobre imágenes (Grupo 2)

GrIDsure (Figura 1.7(c)) [**Brostoff2009Gridsure**] es un métdo de autenticación en el que se muestran números en una cuadrícula de 5 x 5. Los usuarios deben seleccionar y memorizar el patrón realizado por un sub-conjunto de los 25 números mostrados. Para crear la contraseña se introducen por teclado los números que conforman el patrón. Para autenticarse el usuario debe recordar el patrón e introducir la nueva secuencia de números que lo conforman que cambiará en cada intento de autenticarse. En un estudio [39] se registró un 87 % de éxito en el proceso de autenticación con contraseñas de longitud 4.

En la figura 1.8 se puede observar un resumen de los principales métodos dentro de esta categoría y su evolución.

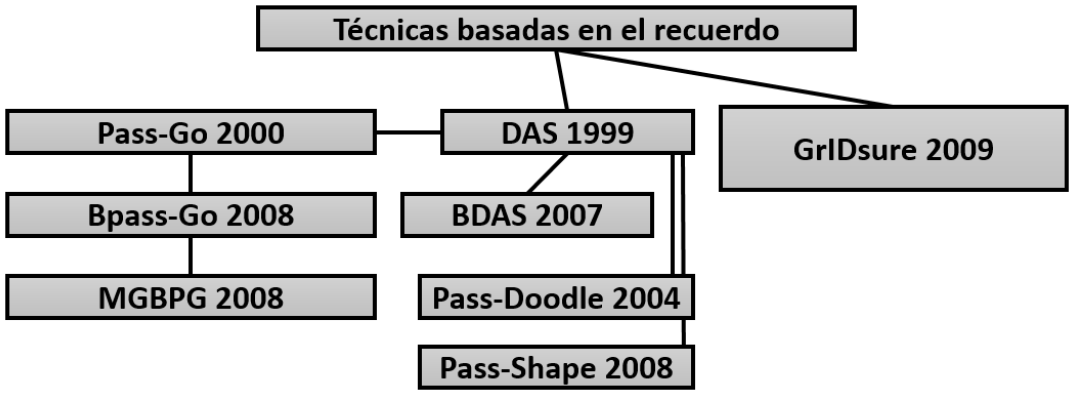


Figura 1.8: Evolución de las técnicas de autenticación gráficas en la categoría Técnicas basadas en la memorización de patrones en imágenes

1.1.3. Técnicas basadas en el recuerdo con indicación

En esta categoría se requiere que el usuario memorice un conjunto de puntos en áreas predeterminadas de una imagen o conjuntos de ellas. En la idea original de Blonder, el usuario para registrarse debía seleccionar con un mouse o un lapicero en determinados puntos de una imagen, en la fase de autenticación si lo hacía de forma correcta este sería aceptado por el sistema de lo contrario sería rechazado.

Passlogix [7], ha desarrollado varios métodos de autenticación gráfica que se encuentran dentro de esta categoría y que básicamente buscan repetir una secuencia de acciones. Uno de sus ejemplos más preponderantes es el vGo en el que los usuarios pueden mezclar un cóctel virtual y usar la combinación de ingredientes como una contraseña. Otras opciones de contraseñas incluyen seleccionar una mano de cartas, o preparar una cena en una cocina virtual. Estas propuestas poseen un espacio de clave bien pequeño y no existe forma de prevenir que el usuario escoja contraseñas fáciles de adivinar.

PassPoints [77] extiende el funcionamiento del trabajo inicial de Blonder. En este método cualquier imagen puede ser utilizada (pinturas, fotos naturales, fotos familiares, fotos de arquitectura, etc.) lo que hace al sistema más flexible. Las imágenes podían ser seleccionadas por el usuario o proveídas por el sistema. Wiedenbeck et al. [77] en su investigación asegura que las imágenes más deseadas para el proceso debían tener contenido que tuviera significado para el usuario por lo que estas debían contener escenas concretas. También era un requisito adicional que las imágenes seleccionadas fueran intrincadas en el contenido y que tuvieran cientos de puntos memorables diseminados de forma homogénea. El usuario podía seleccionar en estas imágenes cualquier conjunto de puntos para crear su contraseña. Luego en el proceso de autenticación este debe seleccionar los mismos puntos en el orden preciso, con un margen de error (tolerancia) alrededor de cada punto.

Como una imagen puede contener cientos de miles de puntos, el espacio teórico de este sistema es suficientemente grande. Para que el proceso de autenticación fuera efectivo y rápido para el usuario debía existir una región de tolerancia asociada a cada punto (aproximadamente $0,25cm$). Además de que por razones de seguridad requiere que el sistema no almacene la contraseña de forma explícita.

Según Wiedenbeck et al. no se necesitarían muchos puntos para hacer la contraseña segura, con 5 o 6 (En una imágen de $451x331$ pixeles) se pueden lograr más contraseñas que con 8 caracteres dentro de un alfabeto estándar de 64 letras [77]. En la tabla 1.9 tomada de esta investigación se puede apreciar una comparación entre los espacios de clave de la AA y Passpoints variando el alfabeto, la longitud de la contraseña, la tolerancia y el tamaño de la imagen. Se puede apreciar que para 5 puntos y un tamaño de imagen razonable las Contraseñas Gráficas conservan un esacio de clave superior a las alfanuméricas.

	Image size	Grid square size (pixels)	Alphabet size/ No. squares	Length/No. click points	Password space size
Alphanumeric	N/A	N/A	64	8	2.8×10^{14}
Alphanumeric	N/A	N/A	72	8	7.2×10^{14}
Alphanumeric	N/A	N/A	96	8	7.2×10^{15}
Graphical	451×331	20×20	373	5	7.2×10^{12}
Graphical	1024×752	20×20	1925	5	2.6×10^{16}
Graphical	1024×752	14×14	3928	5	9.3×10^{17}
Graphical (1/2 screen used)	1024×752	14×14	1964	5	2.9×10^{16}

Figura 1.9: Comparación de los espacios de clave para Contraseñas Alfanuméricas y Passpoints a partir del tamaño de la imagen, el tamaño de la región de tolerancia, el tamaño del alfabeto, la cantidad de puntos y/o carateres.

Principales elementos negativos de este esquema:

- Algunas regiones de la imagen son más probables de ser seleccionadas para conformar la contraseña [50].
- Para que la contraseña sea efectiva debe contener varios puntos(varios clics sobre la imagen), esto puede extender el proceso de autenticación y de registro mucho más que en un sistema de introducción de caracteres alfanuméricos por lo que lo hace más vulnerable a los ataques de tipo *Shoulder-Surfing*.
- Puesto que es muy difícil para el usuario volver a seleccionar exactamente los mismos puntos en la imagen. Por seguridad no debería guardarse la contraseña de forma explícita. Esto conlleva a la utilización de un mecanismo de discretización para establecer la tolerancia alrededor de cada punto. Una discusión acerca de la importancia y los tipos de discretización en los esquemas de Autenticación Gráficas puede verse en [9].

Cued Click Points (CCP) [13] se propone por los autores como una alternativa más eficiente que el PassPoints, basa su funcionamiento en la idea original de Blonder pero sugiere la utilización de una secuencia de imágenes (total de 5) y de un solo punto en cada una de ellas. La secuencia de imágenes variaría dependiendo de los puntos que el usuario seleccione. Cuando el usuario establece su contraseña, selecciona un punto en cada una de un grupo de 5 imágenes que se le muestran de forma consecutiva (Figura 1.10). Para el proceso de autenticación este debe seleccionar correctamente los puntos que estableció con anterioridad en el proceso de registro de la contraseña. Si selecciona en cada imagen el punto correcto mostrarán las imágenes que el escogió en el proceso de registro (algo que solo él conoce). De lo contrario se le guiará por un grupo de imágenes distinto hasta que al finalizar se le informará que el proceso de autenticación

ha sido incorrecto. Al aumentar el número de imágenes y solo un punto en cada una de ellas aumenta considerablemente el espacio de clave.

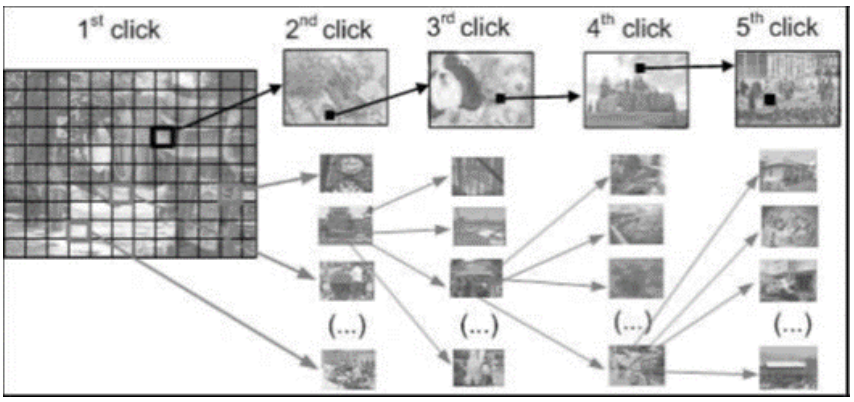


Figura 1.10: CCP: Posibles caminos en dependencia de la selección del usuario

El sistema debe funcionar según los autores en una arquitectura cliente-servidor. El cliente permite al usuario el acceso a un servidor que realiza el proceso de autenticación; las imágenes se almacenan del lado del servidor y la comunicación debe ser cifrada mediante SSL o TLS. Se utilizaría al igual que el PassPoints un mecanismo de discretización para establecer la tolerancia con la que se permitirán autenticar o no. Según los estudios de usabilidad de la investigación original la mayoría de los usuarios prefieren el CCP antes que el PassPoints alegando que cada imagen ayudaba a recordar los puntos seleccionados.

Principales elementos negativos de este esquema:

- Si se obtiene el usuario y la secuencia de imágenes que este ha utilizado para conformar su contraseña, el atacante tiene la información que necesita para ejecutar un ataque.
- Para que el sistema sea eficiente se recomienda un grupo inicial de 1200 imágenes, aún con este límite pueden repetirse imágenes en el proceso de autenticación, aumentar la base de datos de imágenes podría aumentar considerablemente el almacenamiento.
- El sistema básicamente es también vulnerable a los ataques de tipo *Shoulder-Surfing*, incluso más que el PassPoints. Por lo que no se recomienda su uso en lugares donde este tipo de ataques tengan verdadera probabilidad de materialización (Espacios públicos con cámaras, etc.).
- Como no se debe almacenar la contraseña de forma explícita debe basar su mecanismo de discriminación de tolerancia alrededor de un punto en un mecanismo de discretización al igual que el PassPoints.

Cued Gaze-Points (CGP) Se propone como una variante del CCP. Es resistente a los ataques de tipo *Shoulder-Surfing* puesto que la selección de los puntos se realiza con la vista. El usuario mira fijamente a un punto de la imagen y presiona la barra espaciadora para que el sistema guarde su selección. El proceso se repite en cada una de las 5 imágenes. Generalmente este tipo de sistemas requiere para cada usuario una serie de pasos para su calibración y de un hardware especializado que capture los movimientos oculares con presición. La calibración se realiza mirando fijamente un punto sobre la pantalla de esta manera el sistema obtiene la desviación superior para las contraseñas que se introducirán posteriormente por este usuario.

Persuasive Cued Click-Points(PCCP) [**Chiasson2008pccp**] Se propone como mejora al CCP y busca persuadir al usuario en la selección de puntos más aleatorios. En principio es muy parecido al CCP, solo que en el proceso de creación de la contraseña en la imagen se muestra un cuadro que resalta un área aleatoria limitando el espacio donde el usuario puede seleccionar el punto. Existirá un botón que variará a selección del usuario la localización del cuadro. Esto resultaba poco práctico dado que el usuario podía variar la ubicación del cuadro hasta que este estuviera en una región que fuera de su gusto evitando así el principio para el que fué creado. Para el proceso de autenticación se mantiene la idea original.

En la figura 1.11 se puede observar un resumen de los principales métodos dentro de esta categoría y su evolución.

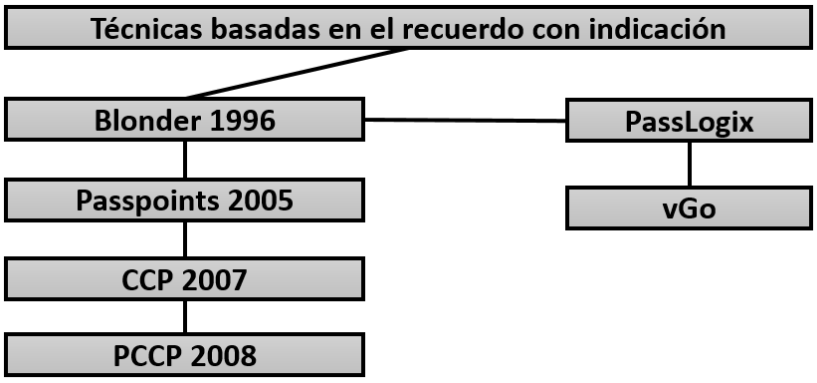


Figura 1.11: Evolución de las técnicas de autenticación gráficas en la categoría Cued-Recall Based Technique

1.1.4. Esquemas híbridos

A partir de las vulnerabilidades detectadas en cada uno de los sistemas se hace evidente la aparición de técnicas que puedan tomar lo mejor de algunos de ellos y combinarlas para darles mayor seguridad. Dentro de esta categoría se pueden agrupar propuestas como la de Jiminy [51], CAPTCHA (*Completely Automated Public Turing tests to tell Computer and Humans Apart*)

[23, 75], Inkblot [60] , Zhao and Li [79], Click-a-secret [22], Gao et al. [24], PassHands [26] y GBFG [35].

1.2. Ataques a Técnicas de Contraseñas Gráficas

1.2.1. Estrategias generales de ataque

Muchos son los procedimientos que tratan de vulnerar los sistemas de contraseñas tanto gráficas como alfanuméricas. La robustez de estos también depende de cuán resistentes son a los distintos tipos de ataques y sus diferentes variantes. A partir de [62] y [27] a continuación se propone un resumen de los más relevantes.

Ataques de Fuerza Bruta: Este tipo de ataques basa su funcionamiento en probar todas las posibles combinaciones de caracteres. Cada combinación es resumida usando una función HASH y comparada con el mismo valor de la original hasta encontrar la correcta. La principal defensa frente a un ataque de fuerza bruta, es tener un espacio de claves lo suficientemente grande para que este tipo de ataques sean muy costosos y tarden en ejecutarse. Una contraseña alfanumérica, tiene un espacio de claves de q^n posibilidades, donde n es el número de caracteres de la contraseña y q el tamaño del alfabeto. Los sistemas basados en Contraseñas Gráficas poseen espacios de clave generalmente mayores como se discutió en el epígrafe anterior.

Ataques de Diccionario: Los ataques de diccionario consisten en construir un diccionario con las contraseñas más probables y probarlas en orden decreciente de probabilidades. Se diferencian de los ataques de fuerza bruta puesto que limitan la búsqueda a las más probables. Los ataques de este tipo pueden llegar a ser muy efectivos; en un pequeño estudio de casos en [34] el 25 % de 14000 contraseñas fueron atacadas con solo 3 millones de entradas en un diccionario de 250000 palabras. Siguiendo el método anterior en [70] un diccionario de 21,5 bits puede ser agotado en 0,22 segundos por un procesador Pentium 4 a 3,2 GHz. Para las CG estos en gran medida dependen de la composición particular de las imágenes, siendo para algunas muy alta la efectividad con que se logran obtener las contraseñas y para otros casos muy bajo.

En las investigaciones de [65, 41, 14, 52, 80] que fueron hechas sobre el PassPoints mezclan Técnicas de procesamiento de imágenes (TPI) con probabilidades, heurística, inteligencia artificial, la información guardada en texto claro por los métodos de discretización y patrones en la forma y orden de selección de los puntos sobre la imagen en Contraseñas Gráficas para construir diccionarios. A partir de estas, se pueden identificar entonces cuatro métodos básicos para la construcción de diccionarios de Contraseñas Gráficas:

- Técnicas de procesamiento digital de imágenes para detectar HotSpots (ej. bordes, centroides, esquinas y objetos a partir de heurística, probabilidades, inteligencia artificial y

redes neuronales).

- Detección de patrones en la forma y orden de selección de los puntos sobre la imagen a partir de las leyes de forma y percepción.
- Información obtenida de la aplicación de métodos de discretización.
- Combinación de las técnicas anteriores.

Spyware: Salvo por algunas excepciones, los *Keylogger* (Programas utilizados para capturar las entradas de teclado sin que el usuario sea consciente) no pueden ser usados para romper las Contraseñas Gráficas. Los *Spywares* de seguimiento del ratón no son del todo efectivos, ya que no basta con saber la posición del puntero. Pues para que este tipo de software sea efectivo tendría que saber en tiempo real lo que se muestra en la pantalla, el tamaño de esta y la posición del ratón. Así pues, frente a este tipo de ataques, las Contraseñas Gráficas ofrecen una mayor seguridad.

Shoulder Surfing: Tanto las Contraseñas Alfanuméricas como las gráficas son vulnerables a estos ataques. Se basa en la posibilidad del atacante de observar o grabar las teclas pulsadas en el teclado (en el caso de ser una contraseña basada en caracteres alfanuméricos) o los clicks del mouse, imagenes seleccionadas, patrón de movimiento en la pantalla (en el caso de ser una Contraseña Gráfica) . Únicamente las técnicas basadas en reconocimientos faciales, voz o similares son capaces de resistir estos ataques.

Ingeniería Social: Las Contraseñas Alfanuméricas, en la gran mayoría de los casos son nombres de personas conocidas, mascotas o fechas importantes como cumpleaños o aniversarios. De forma frecuente, con una mínima investigación sobre un usuario, se puede restringir bastante el espacio de claves. Sin embargo una Contraseña Gráfica, es más difícil de averiguar los posibles lugares donde el usuario pulsaría, ya que requeriría de una investigación más exhaustiva de las imágenes. Frente a otros tipos de ataques incluidos en la ingeniería social, las Contraseñas Gráficas también ofrecen una ventaja sobre las alfanuméricas, ya que es mucho más difícil intentar decir a otra persona cuales son los puntos exactos que forman la contraseña que decir la contraseña basada en caracteres.

1.2.2. Modelos de atención

Los Modelos Visuales de Atención (MVA) estudian la forma en la que las personas observan una imagen. Se estima que un grupo significativo de usuarios escoge los puntos siguiendo estos patrones [52]. De esta manera se pueden construir diccionarios con los grupos de puntos más probables a seleccionar por el usuario.

Los modelos computacionales de atención *Botton-up*, se definen normalmente por características de las imágenes digitales tales como: la intensidad, el color y la orientación [30]. Por otra parte, los modelos computacionales *Top-down*, pueden ser definidos por entrenamiento. La dificultad de estos últimos se basa en que la tarea *Top-down* debe ser predefinida (ej. encontrar personas en una imagen) en un grupo de imágenes que se etiquetan con áreas que contienen a los sujetos [52].

Se abundará en la propuesta de Itti [30, 29] ya que existe evidencia empírica de que en este se captura la forma en la que las personas observan una imagen desde lo profundo hacia arriba (*Botton-up*) [43]. La idea principal de esta propuesta es que algunas áreas de la imagen resalta porque son "salientes" o de alguna manera resaltan por lo que difieren de su entorno. De esta manera dada una imagen el modelo devuelve las localizaciones y el orden en que el ser humano de forma inconsciente y automática la observa. El proceso se compone de dos etapas. En la primera etapa se crea un mapa de "salientes" basado en las caracterísiticas visuales. En la segunda etapa se usa una red neuronal "winner-take-all" con el objetivo de replicar la forma en la que el usuario observaría la imagen. Thorpe et al. en [65] desarrolla un ataque automático de diccionario que se basaba solo en variaciones de la primera etapa donde utilizaba detección de esquinas para encontrar puntos referenciables; luego en [52] se describe como sería la segunda etapa del proceso.

La idea principal (primera etapa) de este método sirve de soporte para las técnicas de análisis y procesamiento de imágenes. Estas se basan en la detección de esquinas y centroides así como la aplicación de herramientas y algoritmos de inteligencia artificial para detectar objetos en las imágenes.

1.2.3. Leyes de Gestalt

Es usual que los usuarios escojan puntos en forma de curvas que luzcan naturales a la forma en que se observa las imágenes y que de esta manera puedan recordarlas fácilmente. Mientras que algunas personas encuentran más sencillo recordar pequeños pedazos de información. Otro grupo significativo prefiere, sin embargo, escoger puntos que poseen relación parcial o total entre sí [41, 69] cumpliendo con las denominadas leyes de Gestalt.

En Alemán Gestalt significa "forma", los principios de esta teoría fueron propuestos por Max Wertheimer en 1912; pero el concepto surgió inicialmente en el 1890 en un artículo titulado "Las cualidades de Gestalt"[33]. Max introdujo cinco leyes de organización de la percepción:

- **Ley de la proximidad o cercanía:** Nuestra percepción tiende a agrupar los objetos cercanos. En la figura 1.12(a) resaltan 3 columnas en vez de 4 filas, dada la separación entre los círculos.

- **Ley de la similitud:** nuestra visión tiende a agrupar los objetos similares en forma. En la figura 1.12(b) dada la similitud de colores resaltan 4 filas.
- **Ley de continuidad:** Los objetos que se encuentran siguiendo una dirección continua son visualmente agrupados. En la figura 1.12(c) vemos dos lineas que se cortan en vez de 4 que se unen en el medio.
- **Ley de cierre:** Nuestra visión tiende a percibir un todo manteniendo el balance y la armonía de la estructura. En la figura 1.12(d) vemos una "S" en vez de pequeños segmentos de linea.
- **Ley del destino común:** Nuestra visión tiende a agrupar los objetos que se mueven en la misma dirección.

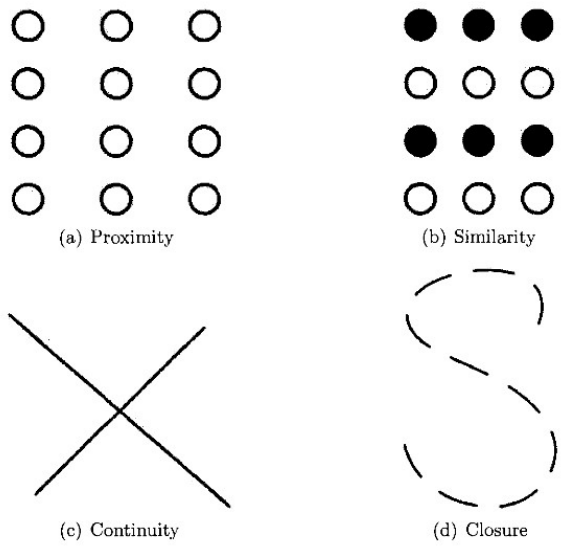


Figura 1.12: Leyes de Gestalt de la percepción visual.

1.2.4. Estrategias de ataques basados en Técnicas de Procesamiento de Imágenes (TPI)

Las TPI, aprovechando las capacidades de las computadoras modernas, permiten analizar miles de datos simultáneamente y cruzarles para encontrar coincidencias. Este procedimiento utiliza a profundidad información recopilada del comportamiento de los usuarios y herramientas digitales para encontrar: salientes, bordes, esquinas, centroides, rostros humanos o partes de ellos, objetos, zonas de colores intensos, etc. A continuación se describen algunos de los métodos de ataques más exitosos.

Ataques de Semillas humanas (*Human Seeded Attack*) En este tipo de ataques se utiliza la información recopilada de un grupo de usuarios para predecir las contraseñas que otro grupo puede escoger sobre una imágen [41]. Utiliza como hipótesis la idea de que los puntos seleccionados por un grupo arbitrario de personas va a tener un alto grado de coincidencia con los que seleccione otro grupo distinto de personas. De esta manera se pretende que las contraseñas almacenadas de un grupo de usuarios puedan ser utilizada para estimar el comportamiento de otro grupo y de esta forma construir un diccionario de ataque. En [65] aseguran que pueden pronosticar correctamente el 36 % de las contraseñas dentro de 2^{31} conjeturas para algunas imágenes en el primer intento y el 20 % dentro de 2^{33} conjeturas en un segundo intento.

Este método en esencia depende de la composición de las imágenes; se resalta en la investigación que para algunas imágenes con composición aleatoria es más difícil efectuar un ataque exitoso dado que se necesitarían mayores muestras iniciales. Como parte de este estudio se analizó además el efecto de los PLC (Se profundizará en ellos en la sección 1.2.6) como forma de capturar la relación entre los puntos que conforman una contraseña. En [41] se determinó que en efecto estos patrones reducen el tamaño del diccionario pués muchos usuarios utilizan estas predisposiciones como reglas nemotécnicas para recordar sus contraseñas. Por lo que la técnica original se vuelve más precisa cuando se cruzan los datos con los diccionarios de PLC.

Ataques automáticos puros (*Purely Automated Attacks*)

En [65] también se investigó un ataque automático puro utilizando TPI. Este ataque creaba el diccionario modelando las decisiones de un usuario utilizando un grupo de métodos y herramientas de procesamiento de imágenes. La idea es que este métodos ayude a predecir los puntos críticos por medios automáticos, lo que lleva a búsquedas más eficientes para ataques exhaustivos. Como premisa, para que un punto fuera candidato a escogerse por el usuario este debía poderse identificar con precisión y a la vez ser distinguible de su entorno. Para lograr estas premisas se implementa una variación del MVA de Itti, *Button-up* y se combina con el método de detección de esquinas de Harris detallado en [28]. La detección de esquinas escoge áreas de una imagen que tienen variación de intensidad en dirección horizontal y vertical.

Como resultado se obtiene una lista de puntos candidatos con la cuál se puede efectuar un ataque de diccionario. Con este método se lograron obtener el 30 % y 29 % de las contraseñas para algunas imágenes bien definidas, pero en otros casos los resultados están por debajo del 2 %. Esto implica que para algunas imágenes este tipo de ataques no es efectivo. Los autores determinan que el método funciona mejor en las imágenes que el MVA devuelve resultados más exactos y decisiones más definidas. En este método no se tuvo en cuenta estrategias nemotécnicas pero los autores reconocen que podría ser mejorado utilizando los PLC.

1.2.5. Ataques basados en detección de patrones

Los patrones son lineas rectas, curvas suaves, arcos o formas geométricas simples formadas por la selección del usuario en una CG. Las personas prefieren recordar menores piezas de información visual [36] y tienden a agrupar información para ayudar a aumentar la memorabilidad [16]. Los ataques de este tipo toman ventaja de las debilidades en la fase de creación de la contraseña para crear el diccionario [25]. Las dependencias entre los puntos que el usuario seleccione pueden reducir drásticamente el espacio de claves [41, 72]. Por lo que combinados con otras estrategias son efectivos puesto que no dependen de la composición específica de la imagen en cuestión.

1.2.6. Patrones identificados en la forma y orden en que el usuario escoge los puntos (PLC)

En la TAG Passpoints existen comportamientos de los usuarios muy interesantes descritos en [14] que fundamentan la idea de que el usuario distribuye los puntos en composiciones independientes de las imágenes de fondo.

- **Distribución de los puntos:** Por ejemplo en el Passpoints, los usuarios tienden a seleccionar el primer punto comenzando por la parte izquierda superior de la imagen y seleccionar los demás hasta la esquina inferior derecha de la misma. Por lo que existe una clara progresión de izquierda a derecha y de arriba hacia abajo. Incluso es posible determinar qué áreas de una imagen son más propensas a contener puntos basándose solamente en el orden numérico en que se seleccionaron sin ningún conocimiento sobre la imagen en cuestión.

- **Longitud de los segmentos:** Se demostró que existía una forma de relacionar las distancias entre los puntos y esta era constante en muchos casos e independiente del orden en que cada punto se selecionó.

- **Ángulos y pendientes:** Muchos de los usuarios de Passpoints tienden a crear lineas rectas con sus puntos (Los ángulos más comunes formados entre dos segmentos de recta están cercanos a 0 grados). La distribución de las pendientes por el eje x muestra que los usuarios favorecen las lineas horizontales seguidas por segmentos verticales hacia abajo (pendientes de 270 grados).

- **Formas:** Se identificaron 5 figuras que se pueden formar en el caso del Passpoints con 5 puntos sin importar la orientación de la forma (En la figura 1.13 se muestran algunos ejemplos gráficos de estas formas). Además en la figura 1.14 se pueden apreciar el porciento de contraseñas que contienen cada una de estas formas.

- **Forma de Linea:** La suma de los valores absolutos de los 3 ángulos es menor a 15 grados. El 26 % de las contraseñas de un estudio realizado en [73] cumplieron con este patrón.
- **Forma de W:** El ángulo 1 y el 3 tienen el mismo signo (van en la misma dirección), el ángulo 2 en dirección opuesta.
- **Forma de Z:** Dos de los ángulos tienen signos opuestos y el tercer ángulo tiene menos de 15 grados (forma una linea recta).
- **Forma de V:** Dos de los ángulos tiene menos de 15 grados y el tercero tiene más de 15 grados.
- **Forma de C:** Los tres ángulos tienen el mismo signo (van en la misma dirección) y la suma del valor absoluto de los 3 es mayor de 180 grados.
- **Otros:** Todo lo que no coincida con los patrones anteriores tiene forma desconocida.

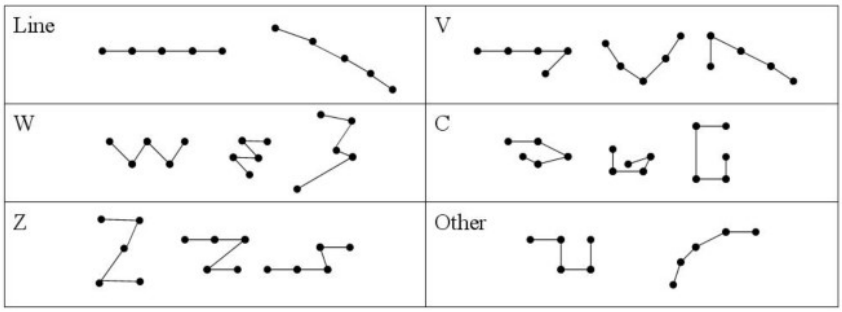


Figura 1.13: Ejemplos de PLC para cada categoría de acuerdo a la forma.

También en [41, 69, 72] se consideran algunos PLC que tienen puntos de encuentro con el estudio previo. Estos se relacionan a continuación:

- **HOR:** Puntos en linea horizontal (de izquierda a derecha o derecha a izquierda).
- **VER:** Puntos en linea vertical (de arriba a abajo o abajo a arriba).
- **DIAG:** Puntos en dirección horizontal y vertical, incluye las lineas rectas.
- **LOD (*Localized Omni-Direction*):** Cada 2 puntos consecutivos de los 5 que conforman la contraseña, están a distancias constantes.
- **CWCCW:** Puntos en sentido horario (a favor de las manecillas del reloj) o anti-horario (en contra de las manecillas del reloj). Se puede definir como secuencias de al menos 3 puntos consecutivos que van en la misma dirección (horario o anti-horario) y la suma de sus ángulos no es mayor de 360^0 .

Cada una de las aproximaciones anteriores tienen en cuenta un error asociado ($t \geq 0$) que relajaría la forma de interpretación del patrón, puesto que es muy difícil que el usuario seleccione por ejemplo 5 puntos en linea perfectamente recta. Como se puede apreciar HOR, VER y DIAG están incluidos en las interpretaciones de 'Forma de linea'que se hicieron en la investigación de Chiasson et al., CWCCW puede verse como una aproximación de las 'Forma de C'y LOD como la interpretación de mantener una cierta distancia relativa entre la longitud de los segmentos imaginarios entre puntos.

Impacto de los ataques utilizando patrones lineales para construir diccionarios: En [69], se recuperaron con la aplicación de DIAG con $t = 9$ y $2^{33,02}$ entradas del diccionario en la imagen de la piscina y los carros respectivamente (En la figura 1.6) el $21,1\,\%$ y el $27,5\,\%$ de las contraseñas. Sin embargo para la aplicación de DIAG con $t = 19$ y $t = 28$ con $2^{35,26}$ entradas del diccionario en la imagen de la piscina y los carros respectivamante el $48{,}2\,\%$ y $54{,}2\,\%$ de las contraseñas.

También con la aplicación de patrones LINE con $t = 9$ y $2^{20,88}$ entradas de diccionario en la imagen de la piscina y los carros respectivamente el $3{,}5\,\%$ y el $22\,\%$ de las contraseñas. Para el mismo patrón pero con $t = 19$ y $t = 28$ con $2^{29,02}$ entradas de diccionario en la imagen de la piscina y los carros se recuperaron respectivamente el $23{,}7\,\%$ y el $52{,}3\,\%$ de las contraseñas.

Los resultados de la aplicación de los diccionarios LINE y DIAG se optimizaron en [69] hasta 7 y 10 veces respectivamente utilizando la variante de estos algoritmos con $t = 19$ y $t = 18$ cruzados con información con los MVA y TPI.

Para el caso de LOD, los resultados de los diccionarios generados con distancias de $20, 40, 60, 80$ y 100 píxeles para la imagen de la piscina es comparable al de DIAG con $t = 19$ y $t = 28$. LOD con 100 píxeles, en este caso con un diccionario de 2^{35} entradas obtuvo el $47,4\,\%$ de las contraseñas.

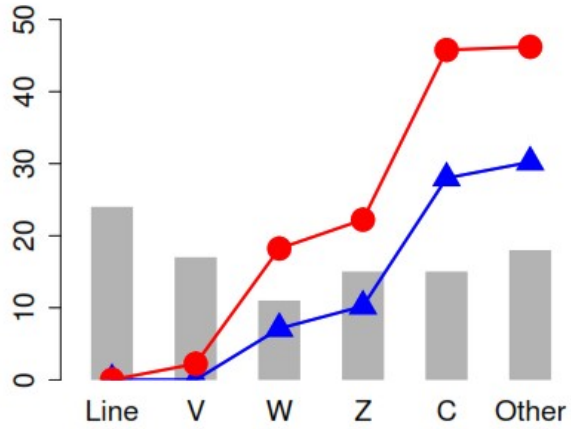


Figura 1.14: Porciento de las contraseñas de [14] que contienen cada uno de los cinco patrones de formas

1.3. Patrón de suavidad de la selección

El patrón de suavidad de la selección es una predisposición de los usuarios a asociar los puntos de la contraseña y seguir caminos en las imágenes de fondo que conduzcan a "selecciones suaves". Estas selecciones estarán determinadas por la ausencia de picos y carecerán de aleatoriedad. De forma visual se podría interpretar como lineas rectas (o casi rectas en cualquier sentido), curvas suaves y caminos sinuosos al menos conectando 4 de sus puntos (Fig. 1.15). El patrón de suavidad agruparía los patrones LINE, DIAG, LOD, HOR, VER, Forma de C, Forma de V y Forma de W ejemplificados en la figura 1.13.

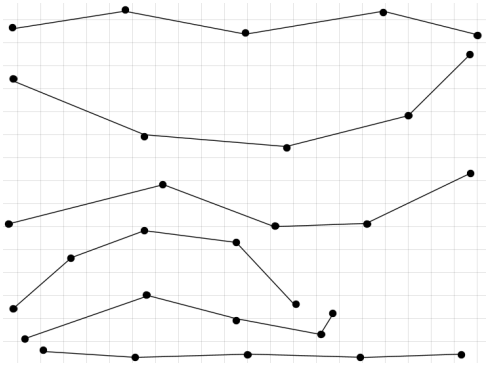


Figura 1.15: Ejemplos de selecciones suaves en conjuntos de 5 puntos.

Estos patrones son más propensas a crearse sobre imágenes que contengan linea de flujo como mapas, carreteras, montañas, lagos, etc. Además también son comunes en imágenes en las cuales los objetos o personas se encuentran alineados siguiendo estas mismas formas. En [14, 73, 69] se demuestra el elevado poder de ocurrencia de este tipo de patrones ante ataques de diccionario.

1.4. Relación entre TPI y PLC

A pesar de que la combinación de las técnicas optimiza los ataques de diccionario y de que los PLC se pueden analizar y encontrar independientemente de la composición de las imágenes. Existen imágenes que son más propensas a inducir patrones en el orden en que el usuario selecciona sus puntos. Las imágenes que tienen significado, flujo o movimiento pueden ser una influencia mayor para que el usuario siga estas lineas inducidas y escoja su contraseña cumpliendo estos patrones.

En la figura 1.16 se observa un claro ejemplo donde se utilizan 2 imágenes (un aparcamiento de carros y piscina con personas). Las zonas rojas equivalen a datos capturados por TPI en [41] para detectar HotSpots. Se puede apreciar en la figura 1.17, que de igual manera las concentraciones de HotSpots responden a PLC luego de aplicarle las leyes de percepción de Gestalt, los MVA y

los PLC propuestos por Chiasson et al. Es evidente que la imagen con carros es más propensa a inducir PLC por la disposición de los objetos que la de la piscina, pero ambas los contienen [67].

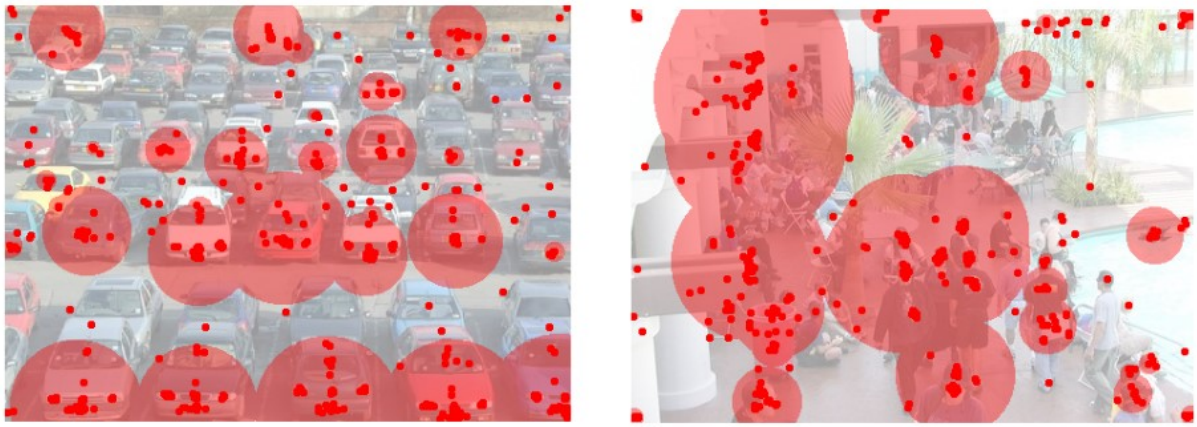


Figura 1.16: Mayores concentraciones de HotSpots.

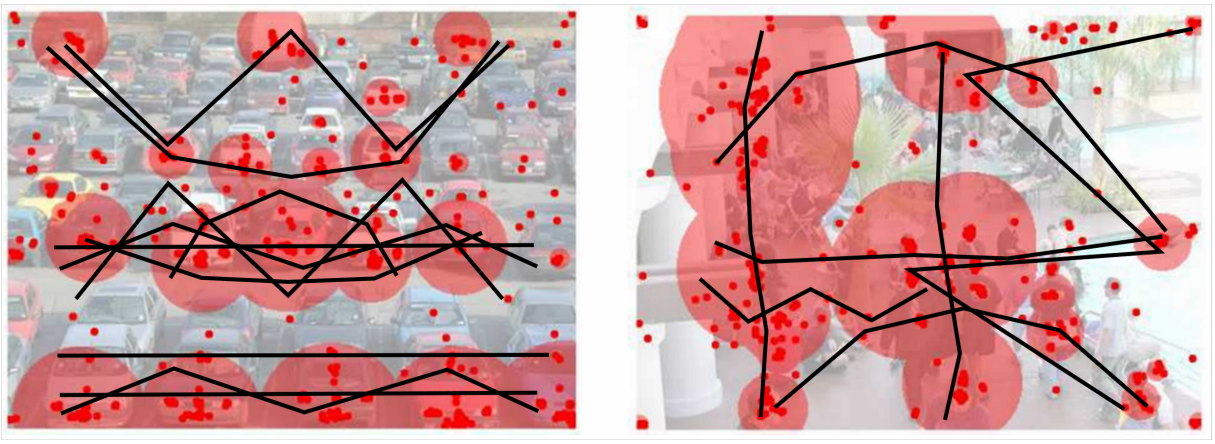


Figura 1.17: Presencia de PLC en las mayores concentraciones de HotSpots.

1.5. Seguridad y usabilidad de las Contraseñas Gráficas

Seguridad: Son muchos los aspectos que se deben tener en consideración a la hora de diseñar un sistema de autenticación, estos van desde la codificación y almacenamiento de las contraseñas hasta la capacidad para resistir ataques tanto en el dispositivo de usuario como desde la Internet [27].

- **Almacenamiento de la contraseña:** en el diseño de un sistema de autenticación es importante la forma en la que se vaya a almacenar los usuarios y contraseñas de todas las

personas registradas en ese sistema. Estos datos, sobretodo la contraseña, no se deben almacenar en texto claro. La forma usual es almacenando el resultado de aplicar una función HASH (Función Resumen) a la contraseña y al usuario. En un sistema online, cuando se envía la solicitud de ingresar en el sistema se debe enviar la información además por un canal cifrado. En un sistema local no existe ese problema al no existir una comunicación mediante una red de datos; aun así la base de datos donde se almacena la información sensible debe estar cifrada. Los únicos métodos de los mencionados en el epígrafe 1.1 que aplican seguridad mediante funciones HASH son Dhamija y Pering con sus recomendaciones, PassFaces, PassPoints, CCP y PCCP.

- **Espacio de claves:** El espacio teórico de claves de una contraseña es el número total de contraseñas posibles que se pueden generar en un alfabeto. Para lograr seguridad ante ataques de diccionario este espacio teórico debería asumir una distribución de contraseñas equiprobables. El tamaño de este conjunto depende del número total de caracteres posibles y de la longitud de la contraseña. En las Contraseñas Gráficas, los caracteres posibles son los puntos donde se puede pulsar en la imagen. Cuanto más grande es el espacio de claves, más seguro es el sistema ya que será más resistente a cierto tipo de ataques como el de fuerza bruta.

  Los sistemas de autenticación con contraseña numérica, tiene un espacio de claves muy pequeño en comparación con otros sistemas de Contraseña Alfanumérica o Contraeña Gráfica. En los sistemas de CG el espacio de claves depende íntegramente de las zonas donde se pueda pulsar. Dependiendo de la técnica de autenticación gráfica y de su implementación este posee una dimensión variable. En [80] se demuestra que las técnicas que la discretización reduce significativamente el espacio de clave. Aplicando Ataques de Diccionario al PassPoints y al PCCP logran obtener para la Discretización Centrada, el 62 % de las contraseñas, y el 39 % para la Discretización Robusta. Todos los métodos dentro de la categoría Técnicas basadas en el recuerdo con indicación destacan por su espacio de clave considerablemente grande.

- **Resistencia a ataques:** Para que una contraseña alfanumérica se considere segura debe ser larga, aleatoria y no debe guardar relación con el usuario [1]. Si una contraseña es larga, la hace más resistente a ataques como los de fuerza bruta o *Shoulder-Surfing*. Si una contraseña alfanumérica es aleatoria la hace más resistente a ataques como los de diccionario o la ingeniería social. Todos los métodos consultados poseen debilidades que los pueden hacer vulnerables a los diferentes ataques. Dentro de estos destacan en la primera categoría las propuestas de Birget y Man (Resistentes a *Shoulder-Surfing*) y el método PassPoints con sus variantes puesto que aplicándole restricciones resiste los ataques de

[1] No deben ser nombres de familiares, mascotas, cumpleaños, números de identidad personal, aniversarios ni fragmentos u combinaciones de estos.

diccionario basados en patrones y detección de HotSpots.

Usabilidad: Aunque el sistema posea muchas características que lo hacen seguro, si no es cómodo o relativamente fácil de usar por el usuario nunca se utilizará en escenarios reales. [27] define la usabilidad como la unión de 3 factores:

- Efectividad: Precisión y grado de éxito en las tareas que realiza un usuario.
- Eficiencia: Relación entre el grado de éxito en las tareas que realiza un usuario y los recursos utilizados para conseguirlo.
- Satisfacción: Evaluación positiva del usuario hacia el sistema.

En [68] se hace una valoración de estos factores por cada categoría:

Todos los sistemas de la primera categoría (Técnicas basados en el reconocimiento) poseen problemas de efectividad y eficiencia. La cantidad de imágenes suele ser grande para garantizar un espacio de clave adecuado y esta restricción afecta en primer lugar la rapidez y el éxito con que el usuario puede culminar el proceso de registro-autenticación. En segundo lugar muchas imágenes pueden afectar la eficiencia aumentando el espacio de almacenamiento en el servidor. En general para cada técnica es evidente que un proceso de autenticación extenso por la utilización de muchas imágenes conduciría a incomodidades para el usuario en el proceso de autenticación.

En la segunda categoría (Técnicas basadas en el recuerdo), las técnicas propuestas como base (DAS, PassGo y GrIDsure) cumplen con los parámetros de efectividad y eficiencia dado que sus restricciones iniciales los conciben solo para escenarios específicos (Escenarios donde el tamaño de la cuadrícula sea pequeño). Destacan las propuestas BDASH, Pass-Doodle, PassShape y Background Pass-Go por contribuir a mejorar las deficiencias de sus métodos originales para escenarios diversos, pero los hacen predecibles y vulnerables a ataques. Entre ellos resalta el Pass-Go para el cuál existen en la actualidad muchas implementaciones de variantes de este sistema para dispositivos móviles.

En la tercera categoría (Técnicas basadas en el recuerdo con indicación) todos los métodos cumplen con el parámetro de efectividad y satisfacción. En los estudios se abunda sobre la rapidez con la que los usuarios comprenden el procedimiento y son capaces de reproducir sus contraseñas de forma efectiva y exitosa a partir de la región de tolerancia. Solo es señalable la influencia de la discretización en la seguridad de las implementaciones.

1.6. Proactive Password Checkers

Debido a las limitaciones de la memoria humana, las personas casi siempre se inclinan a establecer contraseñas fáciles de pronosticar por ataques de diccionarios (Ej. números de teléfonos,

nombres de familia o amigos, palabras en el lenguaje humano, etc). Todos estos conduciendo a vulnerabilidades. Los *Proactive Password Checkers* previenen a los usuarios de escoger contraseñas fáciles de adivinar. Estos forzan políticas para garantizar contraseñas fuertes. Cuando un usuario vaya a establecer una contraseña un *Proactive Password Checker* va a determinar si esta selección cumple las políticas o no y notificará al usuario [20].

El *Password Checkers* analiza la contraseña para decidir si esta es elegible, en caso de no serlo la rechaza. Este tipo de sistema se basa en la filosofía de que con suficiente ayuda y guía del sistema el usuario puede establecer una contraseña memorable de un grupo grande que no es vulnerable a ataques de diccionario. Este tipo de sistemas debe hallar el punto medio entre la usabilidad del sistema y su seguridad. Si este rechaza muchas contraseñas, los usuarios se quejarán porque les será muy complejo el proceso. Por otra parte, si el algoritmo que guía al usuario es muy simple este puede ayudar a los atacantes a refinar sus técnicas. Las políticas deben ser establecidas cuidadosamente y en ellas es importante establecer sugerencias e instrucciones a los usuarios para crear una buena contraseña [78].

Una explicación detallada de este tipo de sistemas y las posibles políticas para AA puede verse en [78, 20, 4]. Lamentablemente para la Autenticación Gráfica no se han encontrado reportes de aplicaciones de este tipo de sistemas.

1.7. Conclusiones del capítulo

A partir de la bibliografía consultada se puede arribar a las siguientes conclusiones:

- Las mejoras a los Sistemas de Autenticación Gráfica deben tener en cuenta varios parámetros: el almacenamiento de la contraseña, el espacio de claves, la resistencia a ataques y la usabilidad como medidas de eficiencia. Siempre tener en perspectiva que si uno mejora el otro empeora.
- Passpoints posee importantes características que ayudan al usuario en el recuerdo de la contraseña. Es simple en su concepto y soporta combinación de estrategias para mejorar sus vulnerabilidades.
- Los usuarios de Passpoints escogen contraseñas sencillas en la medida en la que luego tendrán que usarlas en entornos prácticos.
- La calidad de las imágenes (en cuanto a su composición) es un factor determinante en la seguridad de la TAG Passpoints puesto que no todas son vulnerables en igual medida a los ataques de diccionario.
- En Passpoints el usuario prefiere áreas específicas de la imagen que resalten por poseer

"salientes", picos, esquinas u objetos de colores llamativos y este comportamiento es dependiente de la imágen y de su contenido.

- Las estrategias donde se utlizan TPI son dependientes de la imágen que el usuario utilizó en el proceso de registro.
- El usuario escoge de forma inconsciente la secuencia de puntos de tal forma que estos tienen relación entre sí de manera parcial o total (sobre todo en entornos prácticos), acorde a la forma en que percibe un escenario para garantizar poder recordarlo. Esta apreciación es independiente de la imágen y de su contenido y se basa en las leyes de Gestalt y los Modelos Visuales de Atención.
- Los usuarios de Passpoints prefieren las lineas rectas donde los puntos estén esparcidos por la imagen comenzando de izquierda a derecha ya sea completamente horizontal o en pendiente de arriba a abajo.
- Los Patrones de clics aparecen en muchas de las imágenes de las investigaciones mencionadas ya sea de forma individual o combinados con otras técnicas. Esto puede ser aprovechado por los atacantes puesto que estas características no dependen de las imágenes de fondo utilizadas en la TAG Passpoints.
- Evidencias obtenidas de estudios exhaustivos en [65, 52, 41, 69, 14] demuestran que los ataques de diccionarios utilizando los Patrones lineales de Clics de forma individual o con la informacón cruzada de las Técnicas de Procesamiento de Imágenes, son ataques efectivos para la Técnica de Autenticación Gráfica Passpoints.
- Los *Proactive Password checkers* ayudan al usuario a establecer contraseñas más seguras antes ataques de diccionario. Sin embargo, no se han encontrado en la bibliografía consultada reportes de su aplicación en la Autenticación Gráfica.

Capítulo 2

DETECCIÓN DE CONTRASEÑAS CON PATRÓN DE SUAVIDAD EN PASSPOINTS

Teniendo en cuenta los elementos abordados en el capítulo anterior, se propone el diseño de un algoritmo dirigido a la utilización de las distancias y ángulos entre los puntos que forman parte de la selección del usuario para detectar el patrón de suavidad. En el presente capítulo se explican de forma detallada todos los elementos que intervienen en el diseño de la propuesta así como los pruebas experimentales desarrolladas para su validación.

2.1. Métodos de detección de patrones espaciales de puntos

Las coordenadas de un conjunto de puntos en el plano aportan información individual de cada uno de ellos. Las coordenadas también aportan información sobre todo el conjunto a través de las relaciones entre ellas. La disposición de estos puntos en el espacio conforma lo que se conoce como "Patrón de puntos" [40]. Para llevar a cabo su análisis se asume que la estructura espacial de un patrón dado es el resultado de un proceso puntual. Se entiende por proceso puntual un proceso estocástico que genera tales patrones, compartiendo todos ellos una estructura similar (la ley de dicho proceso). Los puntos son eventos del proceso. Describiendo el tipo de patrón se obtiene información sobre el proceso puntual que lo ha originado.

En [40, 56] clasifican estos patrones según la relación entre sus puntos en tres categorías (Fig. 2.1):

- Patrón Agregado: densidad elevada en determinadas zonas.
- Patrón Aleatorio: Sin estructura, la posición de los puntos es independiente entre si (CSR)[1].
- Patrón Regular: Densidad constante y los puntos se encuentran alejados entre si.

[1]Es usual denotarlo por CSR por las siglas en inglés de "Aleatoriedad Espacial Completa"

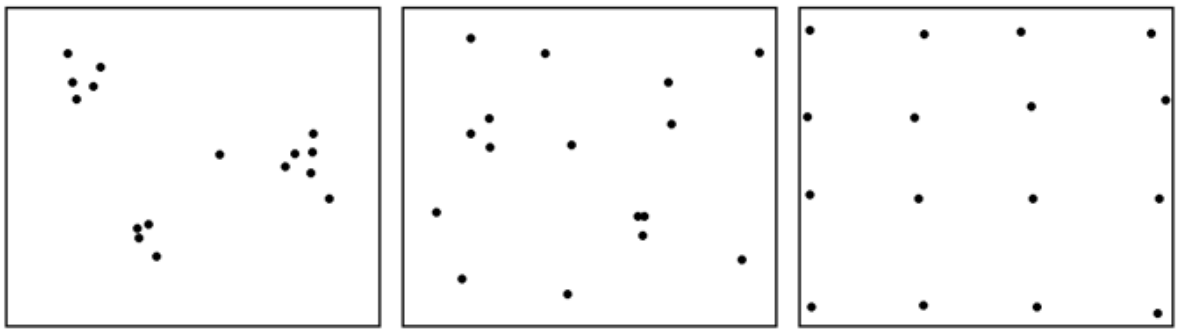


Figura 2.1: Patrones de puntos. Izquierda a derecha: Agregado, Aleatorio y Regular.

Si un grupo de puntos es aleatorio (ausencia de patrones) entonces la distancia entre los puntos sigue una distribución de Poisson. Para decidir si una muestra de puntos es aleatoria (CSR), se evalúa el ajuste de sus distancias entre puntos a la distribución de Poisson [40].

Las propiedades a comparar pueden ser:

- **Propiedades de primer orden:** La intensidad del proceso, definida como la densidad (número de puntos por unidad de área).
- **Propiedades de segundo orden:** Distancia entre puntos.

Para la búsqueda y análisis de patrones de puntos espaciales, algunos de los métodos más usados son el análisis de cuadrantes, el criterio de vecino más cercano y la función K de Ripley.

Análisis de cuadrantes: La metodología de análisis de cuadrantes divide la zona de estudio en unidades regulares, cuadrantes, y estudia el número de puntos que aparecen dentro de cada una. Con la serie de datos que indica el conteo de puntos en cada cuadrante, se procede al análisis estadístico. Este puede hacerse comparando los conteos en los cuadrantes o según la relación entre la media y la varianza de la serie.

El análisis de cuadrantes no es en realidad una medida del patrón, sino de la dispersión. Además, debido al uso de una unidad de análisis (el cuadrante) fija, puede no ser capaz de localizar agrupamientos locales en esta. Otra debilidad de este método es que no es capaz de diferenciar entre distribuciones tales como las de la figura 2.2, claramente distintas pero que arrojan un resultado idéntico al aplicar esta metodología con los cuadrantes mostrados.

Criterio del vecino más cercano: El método del vecino más cercano permite solventar algunos de los problemas asociados al análisis de cuadrantes. Para ello, se basa en las distancias de cada punto a su vecino más cercano. Comparando estas distancias con el valor que cabe esperar en una distribución aleatoria, puede deducirse el tipo de estructura en la distribución observada.

La función K de Ripley: La función K de Ripley trata de incorporar la escala como una

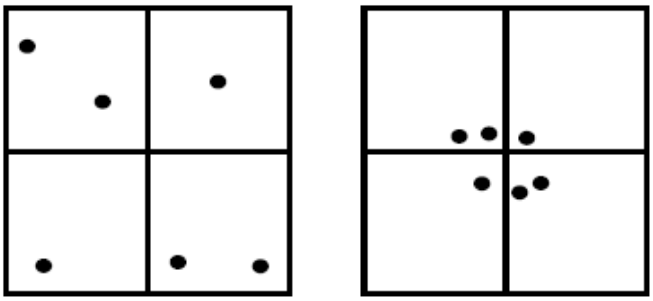


Figura 2.2: Dos disposiciones de puntos distintas que darían un mismo resultado al analizarse por el método de cuadrantes.

variable más del análisis, convirtiendo la dependencia que existe en el análisis de cuadrantes en un hecho favorable, en lugar de una desventaja. Para ello, en lugar de fijar una escala de análisis y una serie fija de cuadrantes de análisis, se tiene una serie aleatoria de zonas de análisis, las cuales se estudian a distintas escalas (con distintos tamaños).

Esta función es una de las más usadas [53, 59, 38], su objetivo es medir la agregación o dispersión de los puntos en el espacio en diferentes distancias.

Al valorar la posible aplicación de estos criterios para detectar patrones de puntos en contraseñas gráficas, se destacan algunas características propias de este nuevo escenario que en nuestra opinión reducirían su efectividad práctica.

- Tamaño de la muestra: En Passpoints el tamaño de la muestra es de solo 5 puntos y en los *test* consultados $*10^2$ como mínimo.
- Orden de los puntos: El orden de los puntos es relevante en el caso de Passpoints; irrelevante en los *test*.
- Estos *test* solo buscan la densidad o acumulación, para determinar si el conjunto de puntos posee o no aleatoriedad; no permiten diferenciar entre los tipos de patrones de puntos identificados para la Autenticación Gráfica.

Se hace necesario definir nuevos criterios de detección de patrones de puntos que se ajusten a las Contraseñas Gráficas que sean efectivos en las condiciones específicas de este tipo de escenario.

2.2. Modelando la suavidad en 5 puntos

Primero se propone una definición más rigurosa de suavidad para $k = 3$ puntos que se ajuste a los conceptos de línea recta y arcos donde no existan picos. Inicialmente se reducirá la definición

a solo tres puntos $(A, B, C\ )$ y los segmentos ente ellos, para luego extenderlo a $k > 3$.

Sean 3 puntos ordenados $P_1 = (X_1, Y_1)$, $P_2 = (X_2, Y_2)$, $P_3 = (X_3, Y_3)$ como se muestra en la figura 2.3. Sean los vectores que los unen $\overrightarrow{V_1} = (P_1, P_2), \overrightarrow{V_2} = (P_2, P_3), \overrightarrow{V_3} = (P_1, P_3)$. Con $\overrightarrow{V_3} \leq |\overrightarrow{V_1}| + |\overrightarrow{V_2}|$ (La igualdad se cumple si los tres puntos están en línea recta).

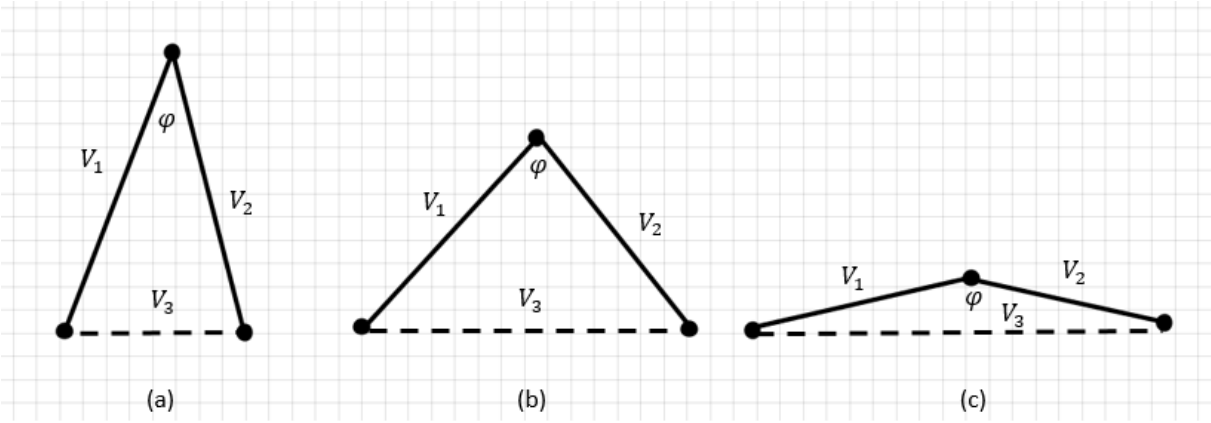


Figura 2.3: Posibles situaciones para el análisis de suavidad en 3 puntos.

Un patrón suave corresponde intuitivamente a la ausencia de picos y significa que el ángulo φ entre V_1 y V_2 es "grande". Para formalizar esta idea se puede fijar un valor φ^0 y definir que existe un patrón de suavidad si $\varphi > \varphi^0$. Este enfoque genera dos problemas: problema I cómo medir φ y problema II cómo escoger φ^0. En la figura 2.3 (c) sería suave, (a) sería no suave y (b) estaría pendiente del valor de la comparación $\varphi > \varphi^0$.

Dado que en situaciones prácticas sería más difícil encontrar las medidas de los ángulos que trabajar directamente con las longitudes de los segmentos entre los puntos; Para medir el ángulo, se utilizará la relación existente entre este y los vectores $\overrightarrow{V_1}$, $\overrightarrow{V_2}$ y $\overrightarrow{V_3}$ y se denotará como D.

Teniendo en cuenta que:

- $|\overrightarrow{V_1}| + |\overrightarrow{V_2}| = |\overrightarrow{V_3}|$ Si $\varphi = 180^o$
- $|\overrightarrow{V_1}| + |\overrightarrow{V_2}| > |\overrightarrow{V_3}|$ Si $\varphi < 180^o$

Se define:

$$D(\varphi, |\overrightarrow{V_1}|, |\overrightarrow{V_2}|) = (|\overrightarrow{V_1}| + |\overrightarrow{V_2}|) - |\overrightarrow{V_3}| \tag{2.1}$$

Para valores fijos de $\overrightarrow{V_1}$ y $\overrightarrow{V_2}$:

$$D(\varphi) = (|\overrightarrow{V_1}| + |\overrightarrow{V_2}|) - |\overrightarrow{V_3}| \tag{2.2}$$

Nótese que:

$$D(\varphi) = 0 \Leftrightarrow \varphi = 180^o \tag{2.3}$$

$$D(\varphi) > 0 \Leftrightarrow \varphi < 180^o \tag{2.4}$$

Relación entre D y φ. Por la ley de los cosenos:

$$cos\varphi = \frac{|\overrightarrow{V_1}|^2 + |\overrightarrow{V_2}|^2 - |\overrightarrow{V_3}|^2}{2|\overrightarrow{V_1}||\overrightarrow{V_2}|} \tag{2.5}$$

$$cos\varphi = \frac{|\overrightarrow{V_1}|^2 + |\overrightarrow{V_2}|^2 + 2|\overrightarrow{V_1}||\overrightarrow{V_2}| - 2|\overrightarrow{V_1}||\overrightarrow{V_2}| - |\overrightarrow{V_3}|^2}{2|\overrightarrow{V_1}||\overrightarrow{V_2}|} \tag{2.6}$$

$$cos\varphi = \frac{(|\overrightarrow{V_1}|^2 + |\overrightarrow{V_2}|^2 + 2|\overrightarrow{V_1}||\overrightarrow{V_2}|) - |\overrightarrow{V_3}|^2}{2|\overrightarrow{V_1}||\overrightarrow{V_2}|} - \frac{2|\overrightarrow{V_1}||\overrightarrow{V_2}|}{2|\overrightarrow{V_1}||\overrightarrow{V_2}|} \tag{2.7}$$

$$cos\varphi = \frac{(|\overrightarrow{V_1}| + |\overrightarrow{V_2}|)^2 - |\overrightarrow{V_3}|^2}{2|\overrightarrow{V_1}||\overrightarrow{V_2}|} - 1 \tag{2.8}$$

$$cos\varphi = \frac{((|\overrightarrow{V_1}| + |\overrightarrow{V_2}|) - |\overrightarrow{V_3}|)(|\overrightarrow{V_1}| + |\overrightarrow{V_2}| + |\overrightarrow{V_3}|)}{2|\overrightarrow{V_1}||\overrightarrow{V_2}|} - 1 \tag{2.9}$$

$$\varphi = cos^{-1}\left(\frac{D \cdot (|\overrightarrow{V_1}| + |\overrightarrow{V_2}| + |\overrightarrow{V_3}|)}{2|\overrightarrow{V_1}||\overrightarrow{V_2}|} - 1\right) \tag{2.10}$$

La expresión (2.10) permite medir el ángulo φ como función de D (soluciona el problema I) para valores fijos de $|\overrightarrow{V_1}|$ y $|\overrightarrow{V_2}|$. Se puede apreciar además que $D(\varphi)$ es función decreciente de φ. Para valores variables de las longitudes de los vectores $|\overrightarrow{V_1}|$ y $|\overrightarrow{V_2}|$ el valor de D estaría determinado además por ellos.

Definición de suavidad para $k = 3$: Para un valor prefijado de φ^0 (Parámetro de tolerancia), se dirá que los tres puntos (P_1, P_2, P_3) contienen un patrón de suavidad a nivel φ^0 (Suaves a nivel φ^0) si cumple que $D(\varphi, V_1, V_2) > D(\varphi^0, V_1, V_2)$.

Definición de suavidad para $k = 5$: Para un valor prefijado de φ^0, se dirá que los cinco puntos $(P_1, P_2, P_3, P_4, P_5)$ contienen un patrón de suavidad a nivel φ^0 (Suaves a nivel φ^0) si cumplen que los tres conjuntos de puntos (P_1, P_2, P_3), (P_2, P_3, P_4), (P_3, P_4, P_5) son simultáneamente suaves a nivel φ^0. En la figura 2.4 se muestra un conjunto de cinco puntos suaves. Análogamente se puede generalizar para cualquier $k > 3$.

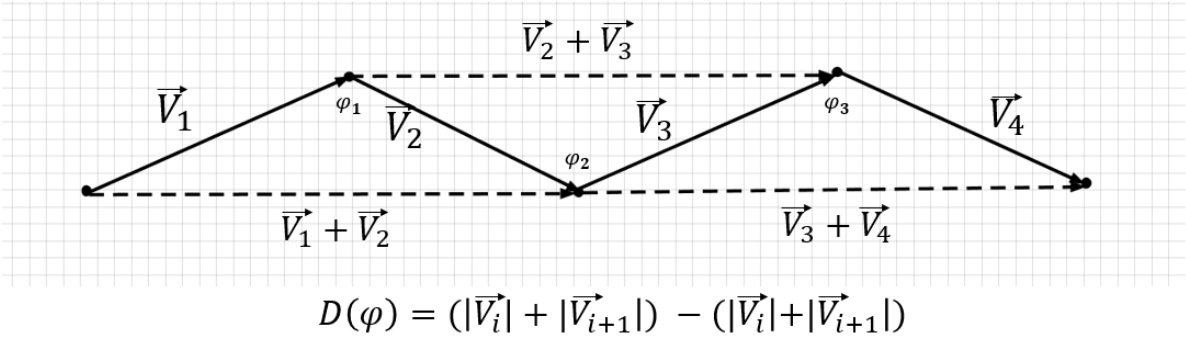


Figura 2.4: Interpretación para $k = 5$

2.3. Algoritmo de detección de la suavidad en n puntos

Se propone un algoritmo que detectaría la suavidad para $k = 5$. El algoritmo toma como entrada una lista (Linea 1, P) con los cinco puntos (P_1, P_2, P_3, P_4, P_5) que seleccionó el usuario en el proceso de registro. Además recibe también el valor del parámetro de tolerancia ($D(\varphi^0)$) (Línea 1, Dp0). Para iniciar se utiliza una variable que cuenta cuántos de los 3 conjuntos de puntos son suaves (línea 4). A partir de la lista de puntos se construyen 4 vectores (Líneas 5 y 6). Se recorre la lista de vectores y se calcula el valor del parámetro $D(\varphi)$ (Línea 10). En cada iteración se compara el valor de sus valores y el valor de $D(\varphi)$ obtenido y $D(\varphi^0)$ (Línea 12). Si el valor de $D(\varphi)$ es mayor que $D(\varphi^0)$, se incrementa el contador (Línea 13). Si los tres conjuntos son suaves, el algoritmo devolvería "Verdadero(Suave)" (Líneas 16 y 17).

Algoritmo 2.1 Algoritmo de detección de suavidad.

```
1: function esSuave(P, Dp0)
2:     Entrada: P: Lista de cinco puntos, Dp0: Tolerancia
3:     Salida: Verdadero(Suave) o Falso(No suave)
4:     contador = 0
5:     se construye la lista de 4 vectores a partir
6:     de los puntos (ListaV).
7:     Recorrer lista de vectores
8:     for i = 1 : 4 do
9:         Calculo el valor de D(φ)
10:        Dp(φ) = mod(ListaV[i] + ListaV[i + 1])−
11:        mod(ListaV[i]) + mod(ListaV[i + 1])
12:        if Dp > Dp0 then
13:            incrementar contador
14:        end if
15:    end for
16:    if contador = 3 then
17:        return Verdadero(Suave)
18:    else
19:        return Falso(No suave)
20:    end if
21: end function
```

2.3.1. Ejemplo de implementación en Python

Python es un lenguaje de programación interpretado cuya filosofía hace hincapié en la legibilidad de su código. Se trata de un lenguaje de programación multiparadigma, ya que soporta orientación a objetos, programación imperativa y en menor medida, programación funcional. Es un lenguaje interpretado, dinámico y multiplataforma.

A continuación se muestra un ejemplo de implemetación del algoritmo anterior. Se hace uso de la biblioteca *numpy* para el uso de la función *norm* que calcula la norma de un vector.

```
import numpy as np

def es_suave(self, coord, dt):
    vectores = []
    vectores.append([coord[1][0] - coord[0][0], coord[1][1] - coord[0][1]])
    vectores.append([coord[2][0] - coord[1][0], coord[2][1] - coord[1][1]])
    vectores.append([coord[3][0] - coord[2][0], coord[3][1] - coord[2][1]])
    vectores.append([coord[4][0] - coord[3][0], coord[4][1] - coord[3][1]])
    contador = 0
```

```
for i in range(3):
    dp = np.linalg.norm(vectores[i] + vectores[i+1]) -
            (np.linalg.norm(vectores[i]) + np.linalg.norm(vectores[i+1]))
    if dp > dt:
    contador += 1
if contador == 3:
    return True
else:
    return False
```

2.4. Selección del parámetro $D(\varphi^0)$

Para solucionar el problema II (fijar φ^0) se diseñaron 3 escenarios.

Primer escenario (Generación de contraseñas con patrones): se recolectaron datos reales de un grupo de 60 usuarios, estudiantes de 3er año de la carrera de Ingeniería en Ciencias Informáticas de la Universidad de las Ciencias Informáticas (UCI) de Cuba. Se contó con una implementación básica de Passpoints para la web con dos imágenes de $700x400$ pixeles. Para influenciar la selección y aumentar la ocurrencia de patrones en las contraseñas recolectadas, se les explicó a los participantes en lo que consistían los patrones en una contraseña de Passpoints. En dos sesiones de trabajo se lograron capturar 397 contraseñas con patrones pertenecientes a todas las clasificaciones. Se graficaron y clasificaron las contraseñas visualmente. Se observó y decidió que 124 contraseñas cumplían con el patrón de suavidad.

Las figuras 2.5 y 2.6 ilustran las características de las contraseñas clasificadas como suaves. Se puede apreciar en las longitudes de los ángulos que estos en su gran mayoría corresponde a águlos cercanos a 180^0.

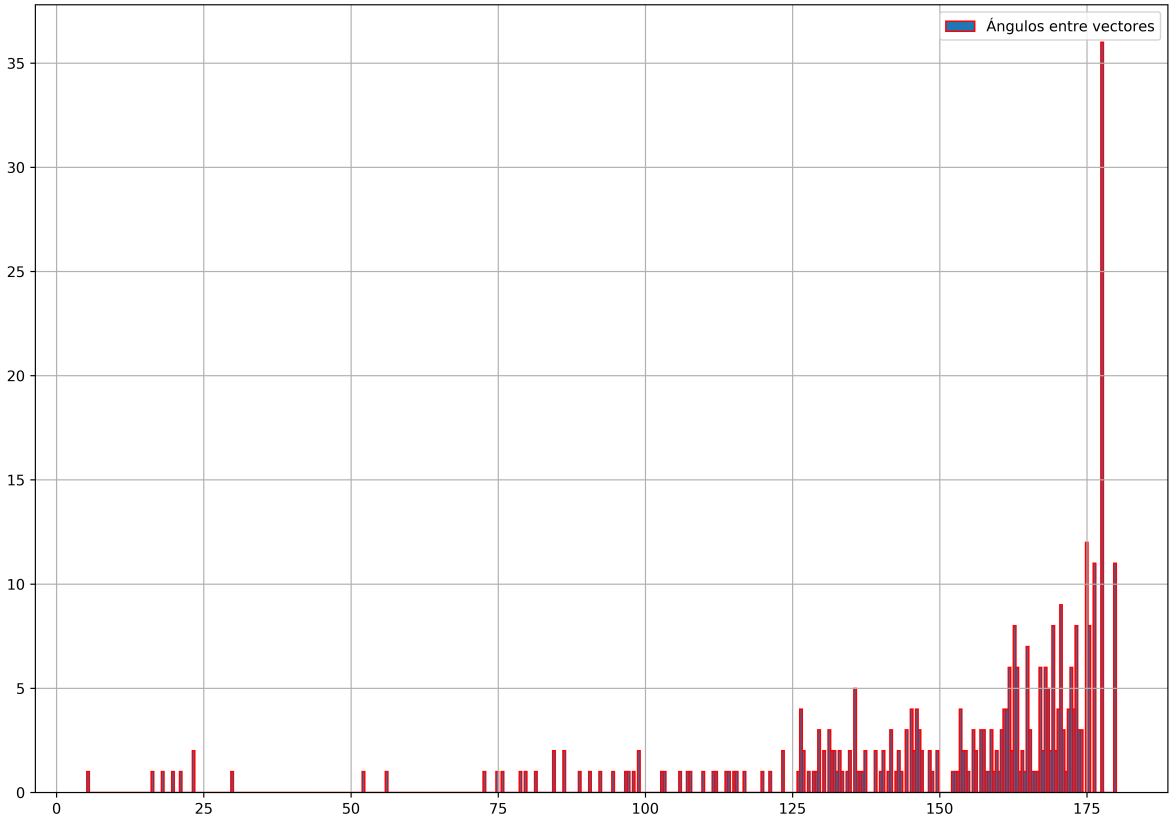


Figura 2.5: Longitudes de los ángulos entre los vectores en las 124 contraseñas clasificadas con patrón de suavidad

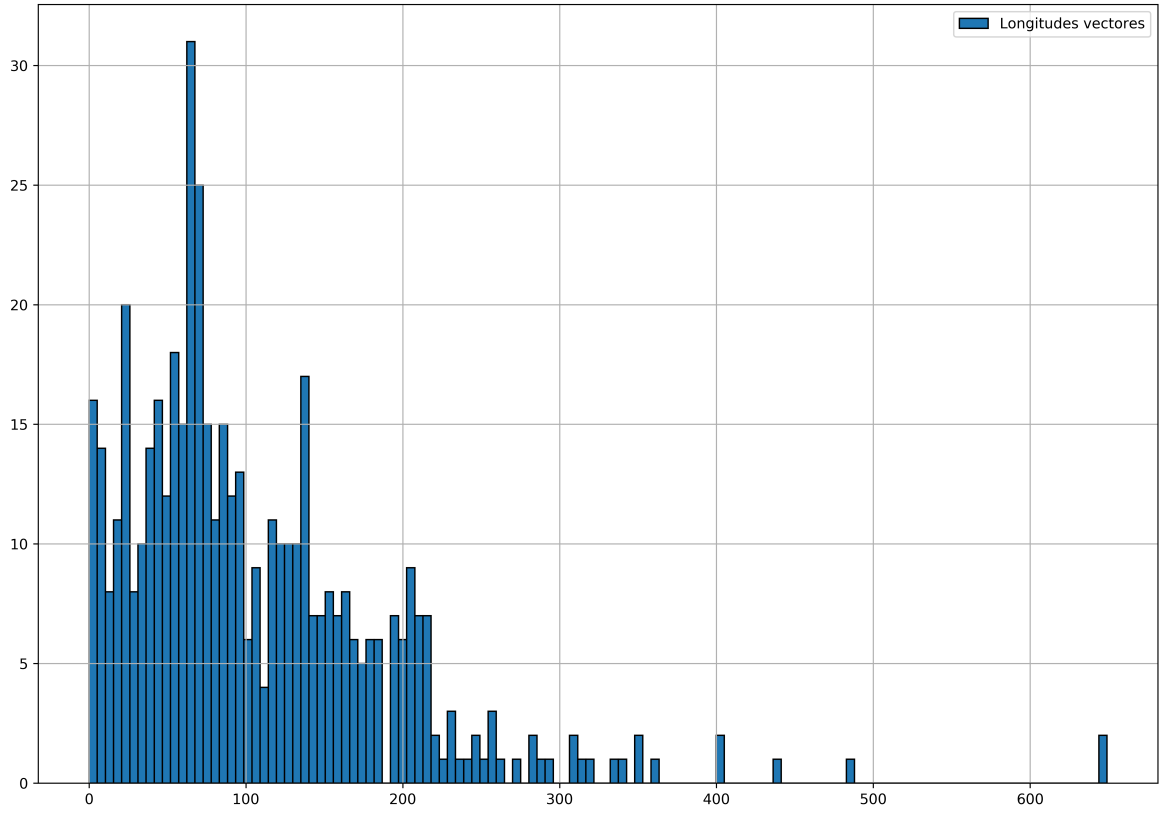


Figura 2.6: Longitudes de los vectores en las 124 contraseñas clasificadas con patrón de suavidad

Segundo escenario (Aplicación del algoritmo a las contraseñas con patrones): El objetivo de este experimento fue evaluar la influencia del parámetro $D(\varphi)$ en el porciento de falsos positivos [2] y negativos [3] observados para fijar el valor del parámetro $D(\varphi)$.

Etapa 1 (Aplicación a contraseñas con patrón de suavidad): se le aplicó una implementación del algoritmo propuesto a las 124 contraseñas, variando con paso 10 el parámetro de tolerancia:

$$D(\varphi^0) \in (20, 30, 40, 50, 60, 70, 80, 90, 100, 150)$$

Los resultados obtenidos se pueden apreciar en la figura 2.7.

[2]Falsos positivos: Contraseñas aleatorias que son detectadas como suaves.
[3]Falsos negativos: Contraseñas que cumplen con el patrón de suavidad pero que no son detectadas.

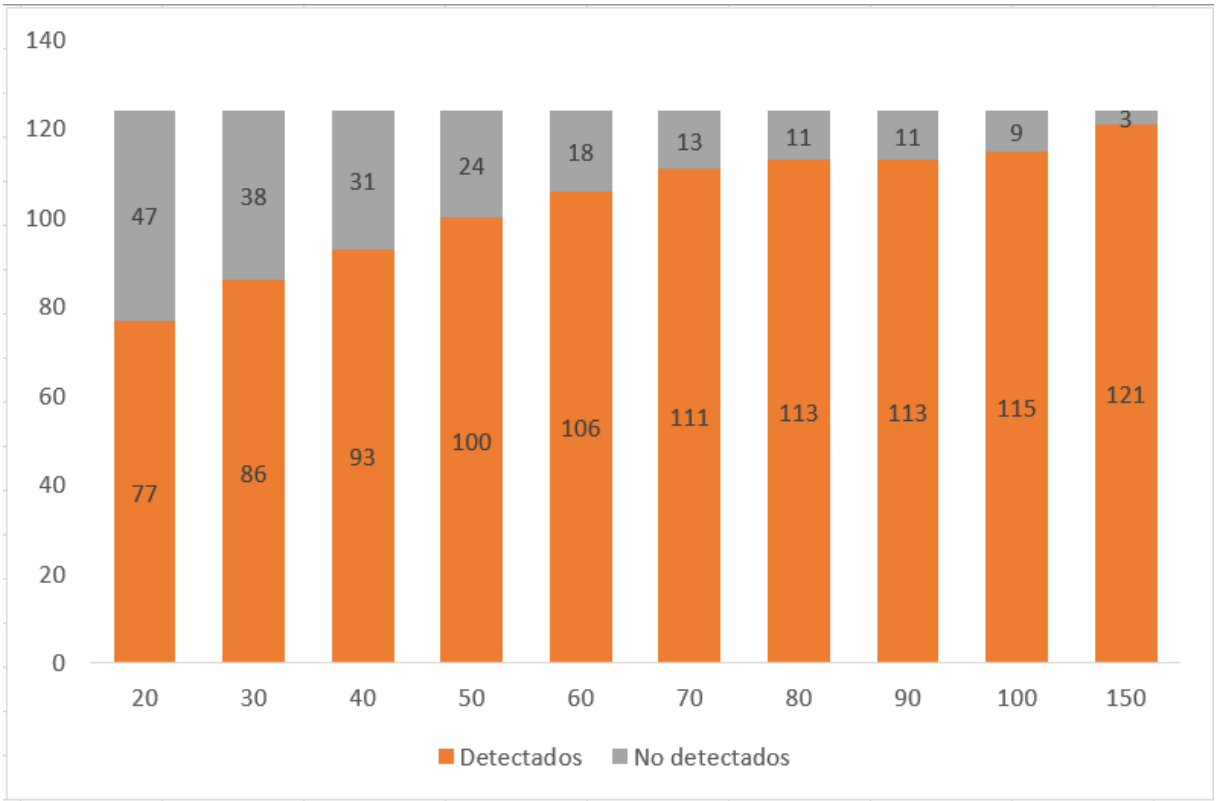


Figura 2.7: Cantidad de contraseñas que se detectan por el algoritmo con patrón de suavidad entre las 124 contraseñas clasificadas como suaves a priori para diferentes párametros de tolerancias. Eje x: Parámetro de tolerancia, Eje y: Cantidad de contraseñas.

Etapa 2(Aplicación a todas las contraseñas): En una segunda etapa del escenario 2 se aplicó el algoritmo a las 397 contraseñas con el objetivo de identificar cuantas nuevas contraseñas detectaba que no estaban en la clasificación inicial del observador. En la figura 2.8 se muestran los resultados de la ejecución.

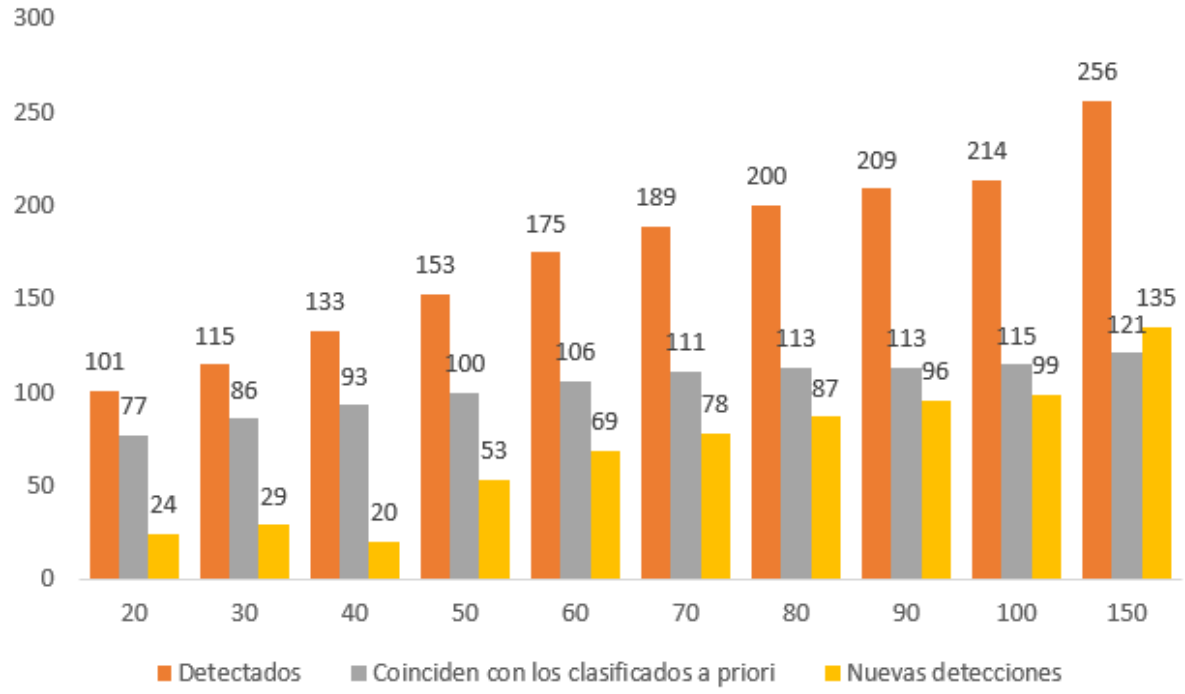


Figura 2.8: Cantidad de contraseñas que se detectan por el algoritmo con patrón de suavidad entre las 397 contraseñas con todos los tipos de patrones. Eje x: Parámetro de tolerancia, Eje y: Cantidad de contraseñas.

Tercer escenario (Aplicación del algoritmo a contraseñas con patrón aleatorio): En un último escenario se aplicó el algoritmo a una base de datos de 400 contraseñas con patrón aleatorio para medir el error de clasificación del algoritmo (falsos positivos). Los resultados se muestran en la figura 2.9

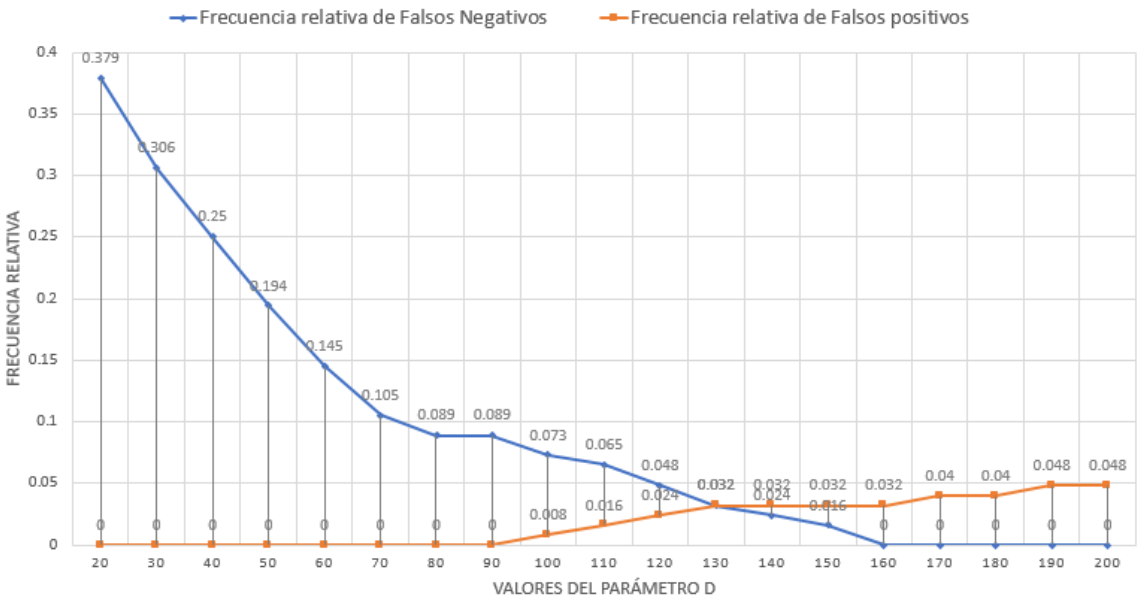


Figura 2.9: Frecuencia relativa de los errores de clasificación del algoritmo (falsos positivos y falsos negativos) para diferentes valores de $D(\varphi)$.

2.5. Discusión de los resultados

En el escenario 2, etapa 1, al aumentar el valor del parámetro de tolerancia como se observa en la figura 2.7 se reducen los falsos negativos. Para valores de $D(\varphi)$ mayores que 80 ocurre poca variación en la cantidad de patrones de suavidad detectados. Incluso para $D(\varphi) = 150$ aún quedan 3 contraseñas que no son detectadas. Esto puede ser debido a error de clasificación por el observador.

En el escenario, 2 segunda etapa, se puede apreciar que para cada valor del parámetro de tolerancia escogido el algoritmo detecta nuevas contraseñas (falsos positivos) suaves cuyo número crece a partir de que la tolerancia se hace mayor de 50. Luego de un análisis exhaustivo y gráfico de cada contraseña no detectada por el observador pero si por el algoritmo se pudo constatar que estas si cumplían con el patrón. Dejando entrever errores de clasificación del observador donde el usuario que escogió la contraseña si estaba buscando relacionar los puntos entre si pero la suavidad no es obvia para el observador.

La figura 2.9 presenta el resultado principal del análisis realizado. Para cada valor de $D(\varphi)$ se observa la frecuencia relativa de falsos positivos y negativos en las contraseñas con patrones (falsos negativos: línea de color azul) y en las contraseñas sin patrones (falsos positivos: línea de color naranja).

En el escenario 3, a partir de la figura 2.9 se propone tomar por defecto $D(\varphi) = 130$ dado

que es buen punto de compromiso entre falsos positivos y falsos negativos. Adicionalmente el gráfico aporta la información necesaria para variar la selección del parámetro en función de las necesidades del usuario. Aumentar el valor de $D(\varphi)$ priorizaría la seguridad y disminuirlo, priorizaría la usabilidad del sistema.

Como se puede apreciar en la ecuación (2.1), el parámetro de tolerancia $D(\varphi)$ también está determinado por las longitudes de los vectores. Los valores propuestos en el análisis del escenario 3 están determinados entonces por la longitud de las imágenes en píxeles. Como trabajo futuro habría que valorar el impacto de aumentar o reducir el tamaño de la imagen en la selección del parámetro $D(\varphi)$.

2.6. Factibilidad de aplicación práctica

Para el cálculo de la complejidad se asume que las operaciones matemáticas, de acceso a el valor de una lista, comparaciones y llamada a funciones representan 1 Operación Elemental (OE, complejidad 1). Desde la linea 4 hasta la 6 se tendrían entonces 13 OE en total (En la construcción de los vectores, 12, y una en la declaración e inicialización del contador). La línea 8 representaría 2 OE y las líneas que están dentro del ciclo representan 13 OE multiplicadas por 3 repeticiones de este. Fuera del ciclo se tendrían en el peor de los casos 2 OE. En total el algoritmo tendría 71 OE.

A partir de ese análisis se puede apreciar que su complejidad temporal es lineal. Esto en términos de consumo de memoria y procesador es despreciable por lo que no afecta la eficiencia del método de autenticación de forma significativa. El algoritmo puede incluirse fácilmente cuando el usuario se va a registrar o cambiar su contraseña en las implementaciones de Passpoints para un escenario similar.

2.7. Conclusiones del capítulo

- No se pueden detectar patrones lineales en AG a partir de los *test* que buscan patrones espaciales de puntos. Estos están diseñados para otros escenarios donde las muestras son mayores, donde el orden de aparición no es relevante y solo se requiere conocer la estructura general en cuanto a la densidad y acumulación.
- El resultado más importante de la investigación es que se obtuvo un criterio efectivo para detectar la existencia de patrones de suavidad en las contraseñas gráficas de la técnica de autenticación gráfica passpoints en imágenes de $700x400$ pixeles y se propuso un algoritmo para su implementación. Se confirmó experimentalmente el criterio propuesto. La aplicación práctica de este algoritmo contribuye a aumentar la seguridad del sistema sin afectar

sustancialmente su eficiencia.

- Se puede modelar la dependencia de los puntos que conforman la contraseña en sistemas basados en Passpoints utilizando las distancias como medida del ángulo formado entre los puntos.
- Fijando en $D(\varphi) = 130$ el parámetro de tolerancia permitió obtener en el escenario propuesto un buen compromiso entre los falsos positivos y negativos. Este puede modificarse para garantizar prioridad en la seguridad o la usabilidad del sistema en el que se utilice el algoritmo.
- El algoritmo permitió constatar que en muchas ocasiones el usuario crea una dependencia entre los puntos que no se nota a simple vista por un observador, sin embargo puede ser detectada por el algoritmo con parámetro de tolerancia variable.
- Puede utilizarse el algoritmo como parte de una implementación de Passpoints en escenarios similares para rechazar la contraseña o alertar al usuario de que su contraseña no es segura por lo que facilitaría ataques de diccionario.

CONCLUSIONES

La presente investigación ha tenido el propósito de obtener un algoritmo para detectar el patrón de suavidad en las contraseñas de la TAG Passpoints. Este tipo de patrón engloba otros que poseen alto nivel de ocurrencia y conducen a vulnerabilidades que pueden ser aprovechadas en ataques de diccionario.

Los primeros pasos se enfocaron en la consulta de la bibliografía referenciada sobre las Técnicas de Autenticación Gráfica, sus características y principales deficiencias desde el punto de vista de la seguridad y usabilidad. Los resultados obtenidos permitieron escoger a Passpoints como un método flexible, fiable y mejorable de entre el resto de las técnicas de la categoría Técnicas basadas en el recuerdo con indicación. Además se pudo apreciar que los patrones lineales de clics (PLC) son una importante vulnerabilidad de esta técnica y que solo utilizando la informacón que estos aportan se podía comprometer la seguridad del sistema.

Ayudar al usuario (antes de hacer definitiva su contraseña en el sistema) a mejorar la elección de su contraseña, podría significar una importante pieza en la fortaleza del sistema sin comprometer su capacidad de recuerdo. Para esto se identificaron además todos los elementos teóricos asociados a la forma de este tipo de patrones y a cuándo estos son más propensos a ocurrir de manera tal que se pudiera definir una forma de modelar su detección en un sistema. La suavidad en la selección del usuario terminó siendo el objetivo, puesto que esta representa un grupo de patrones que tienen todos alto poder de ocurrencia en Passpoints.

Se estableció una definición más rigurosa de suavidad para k puntos, para luego crear un algoritmo que basándose en el criterio propuesto pudiera detectar su aparición con un nivel de tolerancia escogido por el que implemente el algoritmo.

Se validó experimentalmente el criterio propuesto utilizando dos bases de datos de alrededor de 400 CG diseñadas para la evaluación del criterio. Se determinó a partir de los resultados de los experimentos, un grupo de valores, que los autores de la presente investigación proponen como recomendados para la detección de estos en escenarios similares.

RECOMENDACIONES Y TRABAJO FUTURO

Algunas direcciones de trabajo futuro son:

- Desarrollar una aplicación que implemente el algoritmo con versiones para diferentes sistemas operativos y valorar la aceptación por parte del usuario con los valores de $D(\varphi)$ propuestos.
- Valorar el impacto de aumentar o reducir el tamaño de la imagen en la selección del parámetro $D(\varphi, V_1, V_2)$. Se estima que para imágenes grandes existiría una mayor probabilidad de construir contraseñas con patrón de suavidad.
- Valorar si desde la modelación de la clave como vectores se pueden detectar otros Patrones Lineales de Clics reportados en el epígrafe 1.2.6.

PUBLICACIONES DERIVADAS

Durante la investigación llevada a cabo en relación con la tesis presentada, se realizaron las siguientes publicaciones y presentaciones:

- Valdés, O. R., Legón, C. M., Llanes, R. S. Seguridad y usabilidad de los esquemas y técnicas de autenticación gráfica. Revista Cubana de Ciencias Informáticas (RCCI) Vol. 12 (2018). ISSN: 2227-1899. http://rcci.uci.cu.
- Valdés, O. R., Legón, C. C. M., Socorro, C. R., Navarro, P. Patrones en el orden de los clics y su influencia en la debilidad de las claves en la técnica de autenticación gráfica passpoints. IV seminario Científico Nacional de Criptografía. La Habana, Cuba. ISBN: 978-959-16-4125-0
- Valdés, O. R., Legón, C. M., Llanes, R. S. Detección del patrón de suavidad en las contraseñas de la Técnica de Autenticación Gráfica Passpoints mediante Vectores. Congreso Internacional COMPUMAT 2019. La Habana, Cuba.

REFERENCIAS BIBLIOGRÁFICAS

[1] A. Adams y M. A. Sasse, "Users are not the enemy", *Communications of the ACM*, vol. 42, n.º 12, págs. 40-46, 1999.

[2] S. Akula y V. Devisetty, "Image based registration and authentication system", en *Proceedings of Midwest Instruction and Computing Symposium*. 2004, vol. Vol. 4.

[3] F. B. et al., "Proactive password checking with decision trees", *ACM conference on computer and communications security*, 1997.

[4] N. M. D. Aljaffan, "Password security and usability: from password checkers to a new framework for user authentication", Tesis doct., University of Surrey, 2017.

[5] L. G. S. Arash Habibi Lashkari1* Abdullah Gani1 y S. Farmand1, "A new algorithm on graphical user authentication (gua) based on multi-line grids", *Scientific Research and Essays*, vol. 5, n.º 3865-3875, pág. 24, dic. de 2010. dirección: http://www.academicjournals.org/SRE.

[6] V. Autores, *Passfaces: two factor authentication for the enterprise*, www.realuser.com, Consultado 5/11/2019, nov. de 2019.

[7] —, *Passlogix graphical password schemes*, http://www.passlogix.com, Consultado 5/11/2019, nov. de 2019.

[8] V. Bhong y V. Shahade, "Authentication using graphical passwords: effects of tolerance and image choice", *International Journal for Engineering Applications and Technology*, vol. 5, págs. 239-245, 2013.

[9] J.-C. Birget, D. Hong y N. D. Memon, "Robust discretization, with an application to graphical passwords.", *IACR Cryptology ePrint Archive*, vol. 2003, pág. 168, 2003.

[10] S. S. Biswas y S. Sankar, "Comparative study of graphical user authentication approaches", *International Journal of Computer Science and Mobile Computing*, vol. 3, págs. 361-375, 2014.

[11] G. E. Blonder, "Graphical password", US Patent 5,559,961, sep. de 1996.

[12] S. Brostoff y M. A. Sasse, "Are passfaces more usable than passwords? a field trial investigation", en *People and Computers XIV Usability or Else!*, Springer, 2000, págs. 405-424.

[13] S. Chiasson, P. C. Van Oorschot y R. Biddle, "Graphical password authentication using cued click points", en *European Symposium on Research in Computer Security*, Springer, 2007, págs. 359-374.

[14] S. Chiasson, A. Forget, R. Biddle y P. C. van Oorschot, "User interface design affects security: patterns in click-based graphical passwords", *International Journal of Information Security*, vol. 8, n.º 6, pág. 387, 2009.

[15] D. Comaniciu y P. Meer, "Mean shift: a robust approach toward feature space analysis", *IEEE Transactions on pattern analysis and machine intelligence*, vol. 24, n.º 5, págs. 603-619, 2002.

[16] N. Cowan., "The magical number 4 in short-term memory: a reconsideration of mental storage capacity.", *Behavioral and Brain Sciences, 24:87–185, .*, 2000.

[17] S. S. Daf, T. M. Mhaiskey, A. A. Hadke, S. K. Khadke y R. N. Jogekar, "A review on image based graphical user authentication", *International Journal of Engineering Science and Computing*, vol. Vol. 7, 2017. dirección: http://ijesc.org/.

[18] D. Davis, F. Monrose y M. K. Reiter, "On user choice in graphical password schemes.", en *USENIX Security Symposium*, vol. 13, 2004, págs. 11-11.

[19] R. Dhamija y A. Perrig, "Deja vu : a user study using images for authentication", *Proceedings of 9th USENIX Security Symposium*, 2000.

[20] H. S. Dhillon, "Second order markov model based proactive password checker", *Department of Electronics and Communication Engineering, IIT Guwahati, India., Roll*, n.º 04010214, 1967.

[21] P. Dunphy y J. Yan, "Do background images improve draw a secret graphical passwords?", en *Proceedings of the 14th ACM conference on Computer and communications security*, ACM, 2007, págs. 36-47.

[22] M. Éluard, Y. Maetz y D. Alessio, "Action-based graphical password:"click-a-secret"", en *Consumer Electronics (ICCE), 2011 IEEE International Conference on*, IEEE, 2011, págs. 265-266.

[23] H. Gao, X. Liu, S. Wang y R. Dai, "A new graphical password scheme against spyware by using captcha.", en *SOUPS*, 2009.

[24] H. Gao, Z. Ren, X. Chang, X. Liu y U. Aickelin, "A new graphical password scheme resistant to shoulder-surfing", en *Cyberworlds (CW), 2010 International Conference on*, IEEE, 2010, págs. 194-199.

[25] H. Gao, W. Jia, F. Ye y L. Ma, "A survey on the use of graphical passwords in security.", *JSW*, vol. 8, n.º 7, págs. 1678-1698, 2013.

[26] H. Gao, L. Ma, J. Qiu y X. Liu, "Exploration of a hand-based graphical password scheme", en *Proceedings of the 4th international conference on Security of information and networks*, ACM, 2011, págs. 143-150.

[27] M. González Nahón y col., "Estudio de mecanismos de autenticación basados en contraseñas visuales en dispositivos móviles android", Tesis de lic., 2014.

[28] C. G. Harris, M. Stephens y col., "A combined corner and edge detector.", en *Alvey vision conference*, Citeseer, vol. 15, 1988, págs. 10-5244.

[29] L. Itti y C. Koch, "Computational modelling of visual attention", *Nature reviews neuroscience*, vol. 2, n.º 3, pág. 194, 2001.

[30] L. Itti, C. Koch y E. Niebur, "A model of saliency-based visual attention for rapid scene analysis", *IEEE TRANSACTIONS ON PATTERN ANALYSIS AND MACHINE INTELLIGENCE*, vol. 20, n.º 11, pág. 1255, 1998.

[31] W. Jansen, "Authenticating mobile device users through image selection", *WIT Transactions on Information and Communication Technologies*, vol. Vol. 30, 2004.

[32] I. Jermyn, A. J. Mayer, F. Monrose, M. K. Reiter, A. D. Rubin y col., "The design and analysis of graphical passwords.", en *Usenix Security*, 1999, págs. 1-14.

[33] D. B. King y M. Wertheimer, *Max Wertheimer and gestalt theory*. Transaction Publishers, 2005.

[34] D. Klein, "Foiling the cracker: a survey of, and improvements to, password security.", en *In Proceedings of the 2nd USENIX Security Workshop.*, 1990, págs. 5-14.

[35] X. Liu, J. Qiu, L. Ma, H. Gao y Z. Ren, "A novel cued-recall graphical password scheme", en *Image and Graphics (ICIG), 2011 Sixth International Conference on*, IEEE, 2011, págs. 949-956.

[36] S. J. Luck y E. K. Vogel, "The capacity of visual working memory for features and conjunctions", *Nature*, vol. 390, n.º 6657, pág. 279, 1997.

[37] D. Nali y J. Thorpe, "On predictive models and user-drawn graphical passwords", en *Technical Report TR-04-01, School ofComputer Science, Carleton University*. 2004.

[38] J. Negre, F. Muñoz y J. A. Barceló, "A cost-based ripleys k function to assess social strategies in settlement patterning", *Journal of Archaeological Method and Theory*, vol. 25, n.º 3, págs. 777-794, 2018.

[39] T. A. Nikhil y D. Arati, "Graphical passwords authentication: a survey", *International Journal of Computer Science and Mobile Computing*, vol. Vol. 4, 2015, ISSN: 2320â€"088X. dirección: www.ijcsmc.com.

[40] V. Olaya, *Sistemas de Información Geográfica*. http://volaya.es/writing, 2014.

[41] P. C. van Oorschot y J. Thorpe, "Exploiting predictability in click-based graphical passwords", *Journal of Computer Security*, vol. 19, n.º 4, págs. 669-702, 2011.

[42] V. Orschot, P.C y J. Thorpe, "On predictive models and user-drawn graphical passwords", en *ACM Transactionson Information and System Security*. 2008, vol. Vol. 10(4).

[43] N. Ouerhani, R. Von Wartburg, H. Hugli y R. Müri, "Empirical validation of the saliency-based model of visual attention", *ELCVIA: electronic letters on computer vision and image analysis*, vol. 3, n.º 1, págs. 13-24, 2004.

[44] A. S. Patrick, A. C. Long y S. Flinn, "Hci and security systems", en *CHI'03 Extended Abstracts on Human Factors in Computing Systems*, ACM, 2003, págs. 1056-1057.

[45] L. Y. Por, X. Lim, M. Su y F. Kianoush, "The design and implementation of background pass-go scheme towards security threats", *WSEAS Transactions on Information Science and Applications*, vol. 5, n.º 6, págs. 943-952, 2008.

[46] L. Por y X. Lim, "Multi-grid background pass-go", *WSEAS Transactions on Information Science and Applications*, vol. 7, n.º 7, págs. 1137-1148, 2008.

[47] R. W. Proctor, M.-C. Lien, K.-P. L. Vu, E. E. Schultz y G. Salvendy, "Improving computer security for authentication of users: influence of proactive password restrictions", *Behavior Research Methods, Instruments, & Computers*, vol. 34, n.º 2, págs. 163-169, 2002.

[48] P. P. Ray, "Rays scheme: graphical password based hybrid authentication system for smart hand held devices", *Journal of Information Engineering and Applications*, vol. Vol. 2, 2012, ISSN: 2225-0506. dirección: www.iiste.org.

[49] M. Rejman-Greene, "Biometrics—real identities for a virtual world", *BT Technology Journal*, vol. 19, n.º 3, págs. 115-121, 2001.

[50] K. Renaud y A. D. Angeli., "My password is here! an investigation into visio- spatial authentication mechanisms.", en *Interacting with Computers 16*, 2004, págs. 1017-1041.

[51] K. Renaud y E. Smith, "Jiminy: helping users to remember their passwords", en *Annual conference of the south african institute of computer scientists and information technologists. saicsit*, 2001, págs. 73-80.

[52] A. Salehi-Abari, J. Thorpe y P. C. van Oorschot, "On purely automated attacks and click-based graphical passwords", en *Computer Security Applications Conference, 2008. ACSAC 2008. Annual*, IEEE, 2008, págs. 111-120.

[53] U. Schilcher, G. Brandner y C. Bettstetter, "Quantifying inhomogeneity of spatial point patterns", *Computer Networks*, vol. 115, págs. 65-81, 2017.

[54] B. Schneier, "Biometrics: uses and abuses", *Communications of the ACM*, vol. 42, n.º 8, pág. 58, 1999.

[55] —, "Myspace passwords arent́ so dumb", *Wired.com*, 2006. dirección: http://www.wired.com/politics/security/commentary/securitymatters/2006/12/72300?currentPage=2.

[56] H. Shu, T. Pei, C. Song, T. Ma, Y. Du, Z. Fan y S. Guo, "Quantifying the spatial heterogeneity of points", *International Journal of Geographical Information Science*, vol. 33, n.º 7, págs. 1355-1376, 2019.

[57] L. Sobrado y J. Birget, "Graphical passwords", *The Rutgers Scholar, RutgersUniversity, Camden New Jersey*, vol. Vol. 4, 2002.

[58] L. Sobrado y J.-C. Birget, "Graphical passwords", *The Rutgers Scholar, an electronic Bulletin for undergraduate research*, vol. 4, págs. 12-18, 2002.

[59] J. Sporring, R. Waagepetersen y S. Sommer, "Generalizations of ripleys k-function with application to space curves", en *International Conference on Information Processing in Medical Imaging*, Springer, 2019, págs. 731-742.

[60] A. Stubblefield y D. Simon, "Inkblot authentication", *Microsoft Research*, 2004.

[61] X. Suo, "A design and analysis of graphical password", 2006.

[62] X. Suo, Y. Zhu y G. S. Owen, "Graphical passwords: a survey", en *Computer security applications conference, 21st annual*, IEEE, 2005, 10-pp.

[63] T. Takada y H. Koike, "Awase-e: image-based authentication for mobile phones using users favorite images", *Human-computer interaction with mobile devices and services*, págs. 347-351, 2003.

[64] H. Tao, "Pass-go, a new graphical password scheme", Tesis doct., University of Ottawa (Canada), 2006.

[65] J. Thorpe y P. C. van Oorschot, "Human-seeded attacks and exploiting hot-spots in graphical passwords.", en *USENIX Security Symposium*, vol. 8, 2007, págs. 1-8.

[66] J. Thorpe y P. Van Orschot, "Towards secure design choices for implementing graphical passwords", en *Proceedings of the 20th Annual Computer Security Applications Conference (ACSAC), Tucson, USA.* 2004.

[67] O. R. Valdés, C. C. M. Legón, C. R. Socorro y P. Navarro, "Patrones en el orden de los clics y su influencia en la debilidad de las claves en la técnica de autenticacion gráfica passpoints", *IV Seminario Científico Nacional de Criptografía.*, 2018.

[68] O. R. Valdés, C. M. Legón y R. S. Llanes, "Seguridad y usabilidad de los esquemas y técnicas de autenticación gráfica", *Revista Cubana de Ciencias Informáticas (RCCI)*, vol. 12, págs. 13-27, 2018.

[69] P. C. Van Oorschot, A. Salehi-Abari y J. Thorpe, "Purely automated attacks on passpoints-style graphical passwords", *IEEE Transactions on Information Forensics and Security*, vol. 5, n.º 3, págs. 393-405, 2010.

[70] P. Van Orschot y J. Thorpe, "On the security of graphical password schemes.", en *Technical Report TR-05-12, Carleton University, Canada.* 2005.

[71] C. Varenhorst, "Passdoodles: a lightweight authentication method", *MIT Research Science Institute*, jul. de 2004.

[72] J. S. Vorster, "A framework for the implementation of graphical passwords", Tesis doct., University of Liverpool, 12, 2014.

[73] J. S. Vorster, R. P. Van Heerden y B. Irwin, "The pattern-richness of graphical passwords", en *Information Security for South Africa (ISSA), 2016*, IEEE, 2016, págs. 69-76.

[74] E. Walkup, "The password problem", Sandia National Laboratories (SNL-NM), Albuquerque, NM (United States), inf. téc., 2016.

[75] L. Wang, X. Chang, Z. Ren, H. Gao, X. Liu y U. Aickelin, "Against spyware using captcha in graphical password scheme", en *Advanced Information Networking and Applications (AINA), 2010 24th IEEE International Conference on*, IEEE, 2010, págs. 760-767.

[76] R. Weiss y A. D. Luca, "Passshapes - utilizing stroke based authentication to increase password memorability", *In NordiCHI*, págs. 383-392, oct. de 2008.

[77] S. Wiedenbeck, J. Waters, J. Birget, A. Brodskiy y N. Memon., "Passpoints: design and longitudinal evaluation of a graphical password system", *International Journal of Human-Computer Studies*, vol. Vol. 63(1-2), págs. 102-127, 2005.

[78] M. Yıldırım e I. Mackie, "Encouraging users to improve password security and memorability", *International Journal of Information Security*, págs. 1-19, 2019.

[79] H. Zhao y X. Li, "S3pas: a scalable shoulder-surfing resistant textual-graphical password authentication scheme", en *Advanced Information Networking and Applications Workshops, 2007, AINAW'07. 21st International Conference on*, IEEE, vol. 2, 2007, págs. 467-472.

[80] B. B. Zhu, D. Wei, M. Yang y J. Yan, "Security implications of password discretization for click-based graphical passwords", en *Proceedings of the 22nd international conference on World Wide Web*, ACM, 2013, págs. 1581-1591.